

HOT TOPICS · SUPPLIER AND DATA RISK

Know who holds your data.

A certificate authority left customer records, including some passports and driving licences, reachable from the internet for more than a year. A blockchain analytics firm found every user's credentials exposed. A practical playbook for the suppliers who hold what you cannot afford to lose.

INSIDE

Contents

A practical guide to the suppliers who verify identity or hold your most sensitive data: how to map them, what to demand of them, and what to do when one tells you it has been breached.

Foreword 03

Introduction 04

01 Map who holds what 06

02 Demand better 10

03 When they call 15

Questions and checklist 20

Sources 23

FOREWORD

The companies that check who you are can lose the proof.

In late October 2026 DigiCert, one of the best known names in website security, disclosed that a network migration in February 2025 had left an internal archive of customer records reachable from the internet. Most records held business contact details, but a small minority held passports, driving licences or utility bills that customers had uploaded to prove who they were.[1] The data was read in mid 2026 and the access was confirmed in October.[1,2]

In the same fortnight Chainalysis, whose tools many compliance teams use to screen crypto transactions, said an intrusion had exposed names, usernames, password hashes and live tokens for all its users. It took its main services offline while it rebuilt access.[3]

Neither firm's core service appears to have been subverted. But both cases make the same point: the suppliers you trust to verify identity, or to hold your credentials, are themselves a place your data can leak from. Most organisations cannot say which suppliers hold copies of their staff's passports, or which hold tokens that act on their behalf. This playbook helps you find out, fix the contracts and be ready for the call.



The Transputec team
Transputec

INTRODUCTION

Three habits make a supplier breach survivable.

You cannot stop a supplier making a mistake. You can decide what they hold, what they must tell you, and how fast you can respond.

Know who holds what

Keep one list of suppliers that hold identity documents, credentials, tokens or bulk personal data, with an owner for each.

Give them less, and bind them

Send only what is needed, have it deleted when done, and put notification, security and exit terms in writing.

Be ready for the call

Have a tested plan to rotate credentials, assess the risk and decide on reporting within 72 hours.

Every copy of a passport you hand a supplier is a copy you cannot recall.

A password can be changed in minutes. A passport scan, once leaked, stays leaked. That should change what you send, and what you let suppliers keep.

01

PART 01

Map who holds what.

Before you can demand anything, you need to know which suppliers hold your most sensitive data.

01 What happened at DigiCert and Chainalysis

02 Finding the suppliers that matter

03 Sorting them by what they hold

WHAT HAPPENED

Two breaches, one lesson

> **Suppliers in security and compliance are rarely questioned as hard as they should be.**

DigiCert's incident report is unusually candid. A migration moved an internal business system out from behind a VPN. It was treated as infrastructure work rather than a security change, so nobody reviewed what became reachable. A self-registration feature without multi-factor authentication was exposed, and a permissions gap let those accounts read archived records.[1]

Unknown accounts were spotted in June 2026 and treated as a sign-up problem. Only in October did DigiCert establish that records had been read between 27 June and 2 July. It says no certificates were affected, and it is still working out which individuals' documents were involved.[1,2]

Chainalysis's case moved faster but grew in the telling. Its first notice on 30 October described non-sensitive identity data. By 4 November it said all users' password hashes and live tokens had been exposed, and customers had to allowlist IP addresses, reset passwords and rotate API keys before services returned.[3]

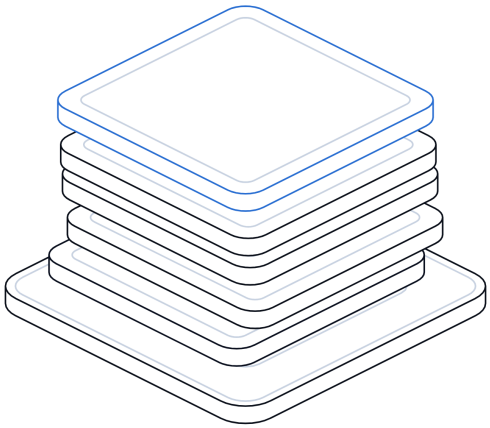
The two firms hold different things for different reasons. One keeps evidence of identity to validate customers. The other holds credentials that let customers use its platform. Both were trusted precisely because their job is security and compliance.

That trust is the problem. Suppliers in these categories are rarely questioned as hard as a new payroll or CRM provider, yet what they hold is often more dangerous to lose. Documents that prove identity can be reused for fraud for years, and tokens can act as you.

So start with a map. You do not need a perfect inventory of every supplier. You need to know, by the end of this month, which ones hold identity documents, credentials or bulk personal data, and who in your organisation owns each relationship.

FINDING THEM

Where sensitive data leaves your hands



01 **Identity checks**

Certificate authorities, right-to-work and background checkers, KYC platforms, ID verification in onboarding apps.

02 **Credentials and tokens**

SaaS tools, integrations and connected apps that store passwords, API keys or OAuth tokens for your users.

03 **Bulk records**

Payroll, pensions, HR, benefits, CRM and outsourced service desks holding staff or customer data.

04 **Privileged access**

Managed service providers and support firms with admin access, and the tools they use to reach you.

SORT THEM

Tier suppliers by what they hold

Spend your effort where a leak would hurt most. Review tier 1 first.

TIER	WHAT THEY HOLD	WHY IT MATTERS	MINIMUM YOU EXPECT
1. Identity	Passports, licences, proof of address, right-to-work evidence.	Cannot be changed after a leak; usable for fraud.	Deletion after checks, short retention, ID-specific breach terms.
1. Keys	Passwords, API keys, OAuth and session tokens.	Can act as you inside other systems.	MFA, IP allowlisting, rapid rotation on notice.
2. Bulk data	Staff or customer records at scale.	Large notification burden and regulatory exposure.	Article 28 contract, audit rights, tested exit.
2. Admin access	Privileged routes into your systems.	A breach there is a breach here.	Named accounts, logging, least privilege.
3. Low risk	Business contact details only.	Phishing risk, little else.	Standard terms and annual check.

02

PART 02

Demand better.

Send less, keep it for less time, and put the rest in a contract you can enforce.

01 Contract terms that matter

02 Assurance worth asking for

03 Minimisation, migration and exit

CONTRACT TERMS

Six clauses to check in every tier 1 contract

UK GDPR Article 28 sets the minimum for processors.[4] These go further where it counts.

01 Breach notice in hours, not "without undue delay"

The law requires a processor to tell you without undue delay; you have 72 hours to report.[5] Ask for 24 hours, with named contacts.

02 What they will tell you

Data types, people affected, time window, cause, and updates as scope changes.

03 Retention and deletion

Identity documents deleted once checks are complete, with written confirmation.

04 Sub-processors

A current list, notice of changes and the same terms passed down.

05 Security change control

Network and platform migrations reviewed as security changes, with re-checked monitoring.

06 Audit and exit

Rights to evidence and audit, plus return or deletion of all data at the end.

ASSURANCE

What each badge does, and does not, tell you

Certificates are a starting point. Ask what is in scope and how recent it is.

EVIDENCE	WHAT IT SHOWS	WHAT TO ASK
ISO/IEC 27001	A managed information security system, independently certified.	Is the service you use in scope? When does the certificate expire?
Cyber Essentials Plus	Basic technical controls, independently tested.	Does it cover the systems holding your data, not just the office?
SOC 2 Type II	Controls tested over a period by an auditor.	Read the exceptions section and the bridge letter.
Penetration test	Point-in-time testing of a system.	Date, scope and whether findings were fixed.
Your own questions	How they handle your data specifically.	Retention, deletion, migration review, breach history.

MINIMISATION

Five rules for sending less

UK GDPR expects you to keep personal data no longer than needed.[6] Apply the same test to what suppliers keep for you.

01 **Verify, then delete**

Ask for confirmation of a check, not a stored copy of the document.

02 **Send the least that works**

A redacted document or a reference number often does the job.

03 **Set a clock on every copy**

Agree a retention period for each data type, and check it is applied.

04 **Scope every token**

Grant integrations the narrowest permissions and shortest lifetimes they will accept.

05 **Clean up at exit**

Ending a contract is not the end of the data. Get deletion in writing.

Migration



When suppliers move, risk moves with them

DigiCert's exposure began with a network migration nobody reviewed as a security change. Ask how your suppliers handle theirs.

WHAT TO ASK

How are network and platform changes reviewed for security? Who signs them off?

WHAT GOOD LOOKS LIKE

An asset inventory updated with every change, and monitoring re-checked after it.

WATCH FOR

Internal tools moved to the cloud, sign-up features left switched on, archives no one uses.

YOUR SIDE

Ask to be told about major migrations of systems holding your tier 1 data.



OWNER

Supplier owner, with IT security

Bring this to the monthly review, with a date for each action.

03

PART 03

When they call.

A supplier tells you it has been breached. What to do in the first day, the first week and after.

01 The first 72 hours

02 Three scenarios

03 Your week, month and quarter plan

THE FIRST 72 HOURS

From the supplier's call to a decision

Your 72-hour reporting clock may start when you become aware of a breach of your data.[5]

Log and assign

Record the time you were told, name an incident lead and open a single channel with the supplier.

Establish what they held

Use your supplier map: which data types, which people, which credentials.

Cut and rotate

Reset passwords, rotate API keys and revoke tokens. Add IP allowlisting if offered.

Assess and decide

Judge risk to people and decide, with your DPO or adviser, whether to report to the ICO and tell individuals.

Track the scope

Expect the picture to change. Diarise follow-ups and revisit decisions with each update.

> **First statements often understate scope. Plan for the second and third update, not just the first.**

THREE SCENARIOS

What a supplier breach looks like in practice

HR AND SECURITY

Your ID checker leaks passports

THE TRIGGER

A verification supplier says some uploaded ID documents were exposed.

TELL PEOPLE

Warn affected staff about identity fraud and phishing; offer practical support.

DO FIRST

Ask exactly whose documents were held, and for what period.

FIX FOR NEXT TIME

Contract for deletion after checks, and stop sending full scans.

IT

A SaaS tool's tokens are exposed

THE TRIGGER

A platform says users' password hashes and live tokens were exposed.

CHECK

Logs for unusual use of the integration during the exposure window.

DO FIRST

Rotate keys, revoke tokens and reset passwords, including anywhere reused.

FIX FOR NEXT TIME

Shorter token lifetimes, IP allowlisting and SSO with MFA.

FINANCE AND HR

Your payroll provider is breached

THE TRIGGER

A processor reports theft of staff records held for you.

TELL PEOPLE

Clear, early message to staff with what to watch for.

DO FIRST

Confirm data types and numbers; start your 72-hour assessment.

FIX FOR NEXT TIME

Test the exit plan and check sub-processors.

PRIORITISE

Where to start

Plot suppliers by how sensitive the data is and how much you know about their controls.

↑ DATA SENSITIVITY

INVESTIGATE NOW

Sensitive, little known

Tier 1 suppliers with no recent evidence. Ask questions this month.

KEEP WATCH

Sensitive, well known

Good evidence on file. Review yearly and after any incident.

QUICK CHECK

Less sensitive, little known

Confirm basics and retention. Do not over-invest.

STANDARD TERMS

Less sensitive, well known

Normal contract terms and annual refresh.

WHAT YOU KNOW ABOUT THEM →

YOUR PLAN

This week, this month, this quarter

A realistic plan for most UK organisations. Owners are suggestions.

WHEN	DO THIS	OWNER
This week	Check whether DigiCert or Chainalysis hold your data; if so, rotate credentials and brief staff.	IT security lead
This week	Name a single owner for supplier data risk and set up a breach contact list.	COO or DPO
This month	Build the tier 1 supplier map: identity, keys, bulk data, admin access.	DPO with procurement
This month	Ask tier 1 suppliers the retention, migration and notification questions in this playbook.	Supplier owners
This quarter	Update contracts at renewal; rehearse a supplier breach as a tabletop exercise.	Legal and IT
This quarter	Delete or recall identity documents suppliers no longer need.	DPO

QUESTIONS

Questions for your board and your suppliers

Ask for evidence, not reassurance.

FOR THE BOARD

- ? Which suppliers hold copies of our people's identity documents, and why?
- ? Could we rotate every credential a supplier holds within 24 hours?
- ? Who decides whether a supplier's breach is reportable to the ICO?

FOR TIER 1 SUPPLIERS

- ? How long do you keep our identity documents, and can you prove deletion?
- ? How do you review network and platform migrations for security?
- ? How quickly will you tell us of a breach, and what will you tell us?

CHECKLIST

Do you know who holds your data?

Tick what is in place today. Anything left blank is your next step.

- [ ] **A tier 1 supplier map exists**
  Identity, keys, bulk data and admin access, with owners.

- [ ] **Identity documents are deleted after checks**
  Confirmed in contract and in writing.

- [ ] **Breach notice terms are in hours**
  With named contacts on both sides.

- [ ] **Supplier credentials can be rotated in a day**
  A runbook exists and has been tested.

- [ ] **MFA and allowlisting on supplier accounts**
  On every account you hold with tier 1 suppliers.

- [ ] **Migration and change questions asked**
  Answers on file for each tier 1 supplier.

- [ ] **A supplier breach exercise has been run**
  In the last 12 months.

GLOSSARY

Words worth knowing

Controller

Under UK GDPR, the organisation that decides why and how personal data is used.

Processor

An organisation that handles personal data on a controller's behalf, under contract.

Article 28 contract

The written terms UK GDPR requires between a controller and a processor.

Certificate authority

A trusted organisation that issues digital certificates after checking who is asking.

API key

A secret that lets one system use another's services. Treat it like a password.

Live token

A credential that keeps a session or integration logged in, often bypassing MFA.

IP allowlisting

Only accepting connections from approved network addresses.

Data minimisation

Collecting and keeping only the personal data you actually need.

Sub-processor

A supplier your supplier uses to handle your data.

Tabletop exercise

A structured walk-through of an incident to test plans and roles.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

01 DigiCert, Unauthorized access to business system, incident report, Mozilla Bugzilla 2084460, Oct to Nov 2026, https://bugzilla.mozilla.org/show_bug.cgi?id=2084460

02 The Register, DigiCert admits 16-month security lapse exposed customer information, 6 Nov 2026, https://www.theregister.com/security/2026/11/06/digicert-admits-16-month-security-lapse-exposed-customer-information/5308097

03 Chainalysis, Security incident (updates 30 Oct to 7 Nov 2026), https://www.chainalysis.com/blog/security-incident-october-30/

04 legislation.gov.uk, UK GDPR Article 28: processor, https://www.legislation.gov.uk/eur/2016/679/article/28

05 legislation.gov.uk, UK GDPR Article 33: notification of a personal data breach, https://www.legislation.gov.uk/eur/2016/679/article/33

06 legislation.gov.uk, UK GDPR Article 5: principles, including storage limitation, https://www.legislation.gov.uk/eur/2016/679/article/5

TRANSPUTEC

Want to know who holds your data?

Transputec helps UK organisations map the suppliers that hold their sensitive data, tighten contracts and access, and respond fast when a supplier reports a breach.

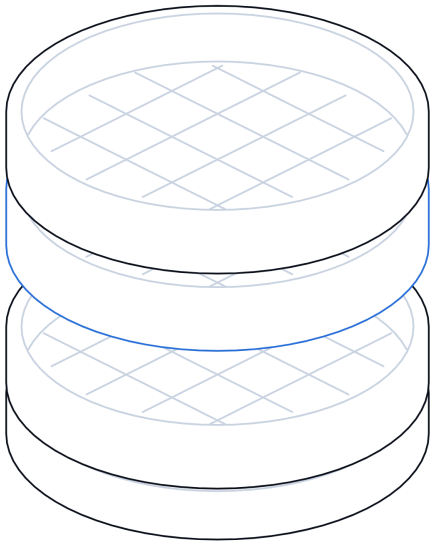
Book a supplier risk review

transputec.com

READ THE COMPANION REPORT

Companion report: Trust, exposed





INTELLIGENCE REPORT · SUPPLIER AND DATA RISK

Trust, exposed.

A certificate authority left an archive of customer records, including some identity documents, reachable from the internet for 16 months. A blockchain analytics firm found every user's credentials exposed. What the two cases say about the suppliers who hold your most sensitive data.

INSIDE

Contents

An evidence-based look at the DigiCert and Chainalysis breaches disclosed in late October and early November 2026, why suppliers that verify identity or hold sensitive data are themselves a breach risk, and what UK organisations should demand of them.

Executive summary 03

Key findings 04

At a glance 05

Timeline 06

01 The archive left open 07

02 The supplier pattern 11

03 What it means for UK organisations 16

Sources 22

EXECUTIVE SUMMARY

The suppliers trusted to prove who you are, or to check who others are, can leak too.

In February 2025 a network migration at DigiCert, one of the world's largest certificate authorities, moved an internal business system out of a VPN-restricted segment and into a zone reachable from the internet. Nobody reviewed it as a security change. Outsiders could self-register accounts and, because of a separate authorisation gap, read archived customer records.[1] Most records held business contact details, but a small minority also held documents such as passports, driving licences and utility bills.[1,2]

DigiCert saw unfamiliar accounts in June 2026, treated them as an account-creation problem, and fixed it. It did not establish that archived data had been read, between 27 June and 2 July 2026, until 19 October.[1] It has not said how many people are affected.[3]

In the same fortnight Chainalysis, whose tools banks and exchanges use to screen crypto transactions, disclosed an intrusion. Its first notice said only non-sensitive identity data was taken. Five days later it said names, usernames, password hashes and live tokens for all users had been exposed, and it took its main services offline.[4,5,6]

Neither firm's core service appears to have been subverted. DigiCert says no certificates were issued or revoked, and Chainalysis says it has no evidence investigations data was accessed.[1,4] But both show how data held for verification or compliance becomes a liability, and how first statements understate scope.

THE BOTTOM LINE

Treat every supplier that holds identity documents, credentials or tokens as part of your attack surface. Know what they hold, hold them to UK GDPR terms, and plan for the day they tell you it has leaked.

KEY FINDINGS

Seven things the evidence shows

01 **A routine migration created the exposure.**

DigiCert's own root cause analysis says the February 2025 move was "treated as an infrastructure change rather than a security change", so no detailed security review took place.[1]

02 **Detection lagged twice.**

The system sat exposed for about 16 months before unknown accounts were noticed, then the data access went unrecognised for another three and a half months.[1,3]

03 **First statements understated scope.**

Chainalysis moved from "non-sensitive" data on 30 October to all users' password hashes and live tokens by 4 November.[4] Counts for DigiCert are still not public.[2,3]

04 **Identity proof is the most dangerous thing to keep.**

Passports and driving licences cannot be rotated like a password. DigiCert says only a small minority of records held them, and is still identifying the people involved.[1,3]

05 **This is a pattern, not bad luck.**

Okta, Snowflake customers and the MOVEit attack on payroll provider Zellis all show sensitive data leaking through a trusted supplier or its customers' access to it.[7,8,9]

06 **UK regulators now fine processors directly.**

The ICO fined Advanced £3.07m in March 2025, its first fine on a processor, and Capita £14m in October 2025.[10,11]

07 **The law on suppliers is tightening.**

The Cyber Security and Resilience Bill, now in its final Commons stages, would bring medium and large managed service providers under regulation.[12,13]

AT A GLANCE

The numbers behind the story

Figures are as disclosed by the companies and regulators. Neither company has published a count of affected people.

16 months

From the February 2025 migration to the first sighting of unknown accounts in June 2026, per DigiCert's incident report.[1]

6 days

The data access window at DigiCert, 27 June to 2 July 2026. Access was confirmed on 19 October.[1]

0

Certificates affected, according to DigiCert. The account was read-only and could not issue, revoke or validate.[1,2]

All users

Chainalysis said names, usernames, password hashes and live tokens for all users were exposed.[4]

£3.07m

ICO fine on Advanced in 2025, the first on a data processor, over a breach affecting 79,404 people.[10]

58 hours

Time Capita took to quarantine an infected device after a high-priority alert, against a one-hour target.[11]

TIMELINE

From migration to disclosure

Dates from DigiCert's incident report and Chainalysis's incident updates. Chainalysis times are US Eastern.

4 Feb 2025

DigiCert migration

An internal business system moves from a VPN-restricted segment into an externally reachable zone.[1]

18 to 24 Jun 2026

Unknown accounts seen

DigiCert sees non-DigiCert accounts, judges they have no data access, and a security programme report confirms external sign-up.[1]

27 Jun to 2 Jul

Archive read

An unauthorised account reads archived customer records. A patch on 2 July closes the gap.[1]

12 to 19 Oct

Data access confirmed

DigiCert first suspects archive access on 12 October and confirms a reportable event on 19 October.[1]

30 Oct

Chainalysis discloses intrusion

It says an external actor used "offensive agentic techniques" and took only non-sensitive identity data.[4,5]

2 Nov

Services pulled

Chainalysis takes Reactor and Data Solutions offline as a precaution.[4]

4 Nov

Scope widens

Chainalysis reports an on-path attack, takes KYT and its login page offline, then says all users' credentials and tokens were exposed.[4]

5 to 6 Nov

DigiCert breach reported

Notifications reach customers and press coverage follows.[2,3]

7 Nov

Chainalysis restores

Reactor, KYT and Address Screening return with enhanced security.[4]

01

PART 01

The archive left open.

How a network change at a certificate authority exposed customer records for more than a year.

01 What DigiCert disclosed

02 How the exposure worked

03 Confirmed and unconfirmed

WHAT HAPPENED

A business system, not the certificate engine

> **Nobody reviewed the migration as a security change. That one decision shaped the next 16 months.**

DigiCert filed a preliminary incident report on Mozilla's public bug tracker on 20 October 2026, as browser root programmes require, and followed it with a full report.[1] The system involved was an internal business system that archives information customers provide, not the systems that issue certificates.

On 4 February 2025, an infrastructure migration moved that system from a VPN-restricted network segment into an externally accessible availability zone. The system shared an account platform with other products, and that platform's self-registration feature, which does not use multi-factor authentication, became reachable from the internet.[1]

Self-registered accounts were not assigned to any application, and reviewers assumed that meant they could see nothing. They were wrong: the authorisation model did not block unassigned accounts from reading data.[1] DigiCert told customers the incident "was initially handled as an account-creation issue rather than a data-access event".[2]

The data accessed was mostly business contact details: names, business email addresses, phone numbers and addresses. A small minority of records also held a customer-provided passport, driving licence, utility bill or similar document.[1] DigiCert says the account was read-only and could not issue certificates, and that CertCentral and DigiCert ONE were not compromised.[2]

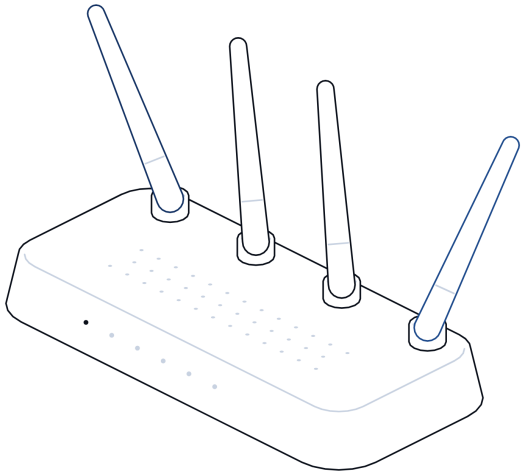
DigiCert has reset all passwords on the system, turned off self-registration, moved endpoints to private addresses, added monitoring and named a single owner for its security.[1] It says it has contacted affected customers and reported the incident to law enforcement, and that it is still reviewing identity documents to identify the individuals involved.[1,3]

To its credit, the report is detailed and candid about causes. What it does not give is a count, which commenters on the bug have asked for. Until that arrives, any customer who uploaded an identity document should assume it may be affected.

HOW THE EXPOSURE WORKED

Three gaps, lined up

DigiCert's root cause analysis names three contributing factors. Any one alone might have been caught.



01 **The network moved**

The migration took the system out from behind a VPN. It was treated as infrastructure work, so no security review took place.[1]

02 **Sign-up came with it**

A self-registration flow built for other products, without MFA, was now reachable from outside.[1]

03 **Permissions assumed too much**

An account with no assigned application could still read archived records. Reviewers assumed it could not.[1]

04 **Monitoring stayed where it was**

Alerts were not reassessed after the move, so new external accounts and bulk reads went unnoticed until October 2026.[1]

WHAT WE KNOW

Confirmed, and not yet confirmed

The position on 8 November 2026. Early reporting on live incidents can change.

QUESTION	CONFIRMED	NOT CONFIRMED
Cause	Migration without security review, sign-up exposed, authorisation gap.[1]	Who created the accounts, and why.
Data	Mostly business contacts; a small minority with ID documents.[1]	How many records, customers or individuals.
Certificates	None affected; account could not issue or validate.[1,2]	Whether exposed data was later used in fraud.
Notification	Customers contacted; law enforcement told.[1]	Which data protection regulators were notified.
Individuals	Review under way to identify people whose documents were held.[3]	When those people will be told.

02

PART 02

The supplier pattern.

Chainalysis, and why the companies that check identity and hold credentials keep turning up in breach reports.

01 What Chainalysis disclosed

02 Two breaches compared

03 A long line of supplier incidents

WHAT HAPPENED

Chainalysis: a scope that kept growing

> **Live tokens held by a supplier are keys to your workflow, not just data about you.**

Chainalysis sells blockchain analytics. Its Reactor tool supports investigations, and its KYT and address screening products help exchanges, banks and payment firms check crypto transactions for links to crime and sanctions. On 30 October 2026 it said an external actor using "offensive agentic techniques" had accessed its systems and internal tools.[4,5]

That first notice was reassuring. It listed user IDs, full names, email addresses and organisation role labels, and said there was no evidence of access to clear-text passwords, MFA secrets or session tokens. It also said the incident was unrelated to the recent Binance theft.[4]

On 2 November Chainalysis took Reactor and Data Solutions offline as a precaution. On the morning of 4 November it said an on-path attack had exposed a subset of customer passwords. Within the hour it took KYT, address screening and its login page offline after detecting abnormal activity.[4]

That night it went further: on Monday 2 November it had found that names, usernames, password hashes and live tokens for all users were exposed. It said it had no evidence that investigations data was accessed or attribution data manipulated, and that it was notifying KYT customers whose accounts appeared to have been used without authorisation.[4]

Restoration required customers to register trusted IP addresses, reset passwords and rotate API keys. KYT and address screening began returning on 6 November, and Reactor on 7 November.[4] Chainalysis has not named the attacker; it said the activity resembled attacks on other tech platforms in recent weeks.[6]

For compliance teams the outage was the immediate problem: transaction screening is a control they rely on. The longer lesson is that live tokens and API keys held by a supplier are keys to your workflow, not just data about you.

TWO BREACHES COMPARED

Different firms, the same lessons

DigiCert and Chainalysis hold different data for different reasons. The failure modes rhyme.

QUESTION	DIGICERT	CHAINALYSIS
Why they hold your data	To validate who is asking for a certificate.	To give customers access to screening and investigation tools.
What leaked	Contact details; some passports, licences and utility bills.[1]	Names, usernames, password hashes and live tokens for all users.[4]
How it surfaced	Months later, once data access was examined.[1]	Within days, with scope widening across updates.[4]
Core service hit?	No certificates affected, per DigiCert.[1]	No evidence of investigations data access, per Chainalysis.[4]
What customers must do	Watch for misuse of identity documents and phishing.	Allowlist IPs, reset passwords, rotate API keys.[4]

THE PATTERN

A long line of supplier incidents

Four earlier cases where sensitive data leaked through a trusted provider or through access to it.

CASE	WHAT HAPPENED	THE LESSON
Zellis and MOVEit, 2023	A flaw in payroll provider Zellis's file transfer tool exposed staff data at BA, Boots and the BBC.[8]	Your data sits in your supplier's suppliers too.
Okta, 2023	First 134 customers; later names and emails of all support system users.[9]	First disclosures are often too small.
Snowflake customers, 2024	About 165 organisations notified; stolen credentials, no MFA, no allow lists.[7]	Your access to a supplier is part of the risk.
Advanced, 2022	Entry via a customer account without MFA; NHS services disrupted; fined £3.07m.[10]	Processors are directly liable in the UK.
Capita, 2023	6.6 million people's data stolen from records held for clients; fined £14m.[11]	One supplier can expose hundreds of clients.

WHY EXPOSURE GOES UNSEEN

How a migration hides a breach for a year

> A system safe only because of where it sat stops being safe the day it moves.

Migrations are the moments when security assumptions quietly stop being true. A system that was safe because it sat behind a VPN is suddenly safe only if every endpoint on it is safe. The firewall rule that did the real work has gone, and nothing on the system itself changes to show it.

DigiCert's report is unusually clear on this. The move was handled as infrastructure work, so the people who would have asked what became reachable were not involved. Its fix is equally telling: a security sign-off and asset inventory update for network access changes.[1]

Monitoring tends to lag behind the change. Alerts are tuned to how a system was used before it moved. New account sign-ups on an internal tool, or steady read requests from an unfamiliar account, do not trip anything because nobody expected them to happen.

Then comes the interpretation error. When DigiCert saw unknown accounts in June 2026 it concluded, reasonably but wrongly, that they could not see data. It fixed the sign-up problem and moved on. Only later did it look at file access and request volumes and find the reads.[1]

Archives make all this worse. Old customer records are rarely used, so nobody notices odd access, and they are often kept longer than needed. UK GDPR's storage limitation principle exists precisely so that data you no longer need is not there to lose.[14]

The general lesson for any organisation, supplier or customer, is simple. Treat every network move as a security change, re-check monitoring after it, and when you find something odd, ask what data it could have reached before deciding it reached none.

03

PART 03

The UK view.

Your legal duties when a supplier leaks your data, and what to demand before it does.

01 Duties under UK GDPR

02 Where you are exposed

03 Recommendations

LAW AND REGULATION

Their breach, your obligations

> **A supplier's breach can start your 72-hour clock.**

Under UK GDPR, a controller must report a personal data breach to the ICO within 72 hours of becoming aware of it, unless it is unlikely to result in a risk to people. A processor must tell the controller without undue delay.[15] If a supplier holds your staff or customers' data on your behalf, its breach can start your clock.

Article 28 requires a written contract with every processor, covering security, help with breach notification, sub-processors, and deletion or return of data at the end of the service.[16] Many contracts do this on paper but never test it.

Some suppliers are not processors. A certificate authority validating your organisation, or an analytics platform holding your users' accounts, may act as a controller in its own right for some data. That does not remove your interest: your people's documents and credentials are still exposed, and you may still owe them a warning.

The ICO has shown it will act against suppliers directly. It fined Advanced £3.07m in 2025 after a breach that began with a customer account lacking MFA, its first fine on a processor.[10] It fined Capita £14m after attackers stole data on 6.6 million people from records held for its clients.[11]

More is coming. The Cyber Security and Resilience Bill reached consideration of Lords amendments in the Commons in November 2026.[12] The government's factsheet says medium and large managed service providers would have to register, apply proportionate security and report significant incidents.[13] It is not yet law, and detail will come in secondary legislation.

None of this is legal advice. But the direction is clear, and the NCSC's supply chain guidance already sets out how to gain control of suppliers in practice.[17] Regulators expect you to know who holds your data and to be ready when they lose it.

WHERE YOU ARE EXPOSED

Four kinds of supplier to look at first

These suppliers hold what attackers want most: proof of identity and the keys to systems.

Identity and verification

Certificate authorities, right-to-work and background checkers, KYC and onboarding platforms. They hold passports, licences and proof of address.

Credential and token holders

SaaS platforms, analytics tools and integrations that hold your users' passwords, API keys or live tokens.

Bulk data processors

Payroll, pensions, HR, CRM and outsourcers that hold records on thousands of staff or customers.

Managed service providers

Suppliers with privileged access into your systems, and the tools they use to manage them.

> **If a supplier holds something that cannot be changed after a leak, such as a passport scan, ask why it still has it.**

RECOMMENDATIONS

Seven things to do now

01 Map who holds what

List suppliers holding identity documents, credentials, tokens or bulk personal data, and name an owner for each.[17]

02 Minimise and expire

Ask suppliers to delete ID documents once verification is done, and set retention in contract.[14]

03 Fix the contract terms

Breach notice within hours, not "undue delay", plus sub-processor lists and deletion at exit.[16]

04 Ask about change control

Ask how network and platform migrations are security reviewed. DigiCert's gap was exactly this.[1]

05 Rotate on notice

Have a runbook to rotate passwords, API keys and tokens for any supplier within a day.[4]

06 Hold your side of access

Enforce MFA and IP allowlisting on accounts you hold with suppliers.[7]

07 Rehearse the call

Practise a supplier breach: who decides on the 72-hour report, who tells staff and customers.[15]

FOR THE BOARD

Questions to put to your leadership team

Ask for evidence, not reassurance.

WHAT WE HAND OVER

- ? Which suppliers hold copies of our people's passports, licences or proof of address, and do they still need them?
- ? Which suppliers hold tokens or API keys that could act on our behalf?
- ? When did we last check that suppliers deleted data at the end of a contract?

WHEN THEY ARE BREACHED

- ? Would our contracts get us told within hours, and who receives that call?
- ? Could we rotate every credential a supplier holds within 24 hours?
- ? Who decides whether a supplier's breach is reportable to the ICO?

GLOSSARY

Terms used in this report

Certificate authority

An organisation trusted by browsers and operating systems to issue digital certificates, after checking who is asking for them.

Availability zone

An isolated location within a cloud provider's region. Moving between zones can change what is reachable.

Self-registration

A feature that lets anyone create an account without an administrator setting it up.

On-path attack

Interception of traffic between two parties. Often called man-in-the-middle.

Password hash

A scrambled form of a password. Weak passwords can sometimes be recovered from hashes.

Live token

A credential that keeps a session or integration logged in. Stolen tokens can bypass passwords and MFA.

KYT

Know Your Transaction. Chainalysis's product for screening crypto transactions for risk.

Controller and processor

Under UK GDPR, the controller decides why data is used; the processor handles it on the controller's behalf.

Storage limitation

The UK GDPR principle that personal data should be kept no longer than needed.

RMSP

Relevant managed service provider: a category the Cyber Security and Resilience Bill would regulate.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

01 DigiCert, Unauthorized access to business system, incident report, Mozilla Bugzilla 2084460, 20 Oct 2026 (full report Nov 2026), https://bugzilla.mozilla.org/show_bug.cgi?id=2084460

02 BleepingComputer, DigiCert data breach exposes customer information, identity documents, 5 Nov 2026, https://www.bleepingcomputer.com/news/security/digicert-data-breach-exposes-customer-information-identity-documents/

03 The Register, DigiCert admits 16-month security lapse exposed customer information, 6 Nov 2026, https://www.theregister.com/security/2026/11/06/digicert-admits-16-month-security-lapse-exposed-customer-information/5308097

04 Chainalysis, Security incident (updates 30 Oct to 7 Nov 2026), https://www.chainalysis.com/blog/security-incident-october-30/

05 The Hacker News, Chainalysis confirms intrusion into its systems, 31 Oct 2026, https://thehackernews.com/2026/10/chainalysis-confirms-intrusion-into.html

06 The Hacker News, Chainalysis breach exposes all users' credentials, forces shutdown of key services, 6 Nov 2026, https://thehackernews.com/2026/11/chainalysis-breach-exposes-all-users.html

07 Mandiant (Google Cloud), UNC5537 targets Snowflake customer instances for data theft and extortion, 10 Jun 2024, https://cloud.google.com/blog/topics/threat-intelligence/unc5537-snowflake-data-theft-extortion

08 The Register, BA, Boots and BBC staff data stolen via MOVEit at Zellis, 5 Jun 2023, https://www.theregister.com/2023/06/05/british_airways_boots_moveit/

09 Help Net Security, Okta breach: hackers stole info on all customer support users, 29 Nov 2023, https://www.helpnetsecurity.com/2023/11/29/okta-breach-customer-support/

SOURCES

Sources and notes

Sources continued. Company statements are quoted as published; neither company had disclosed a count of affected people at the time of writing.

10 BleepingComputer, UK fines software provider £3.07 million for 2022 ransomware breach, Mar 2025, https://www.bleepingcomputer.com/news/security/uk-fines-software-provider-307-million-for-2022-ransomware-breach/

11 Hunton Andrews Kurth, UK ICO fines Capita £14 million following data breach, Oct 2025, https://www.hunton.com/privacy-and-information-security-law/uk-ico-fines-capita-14-million-following-data-breach

12 UK Parliament, Cyber Security and Resilience (Network and Information Systems) Bill, stages, accessed Nov 2026, https://bills.parliament.uk/bills/4035

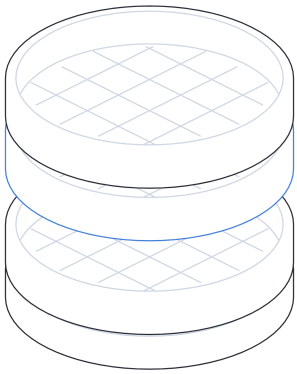
13 GOV.UK, CSR Bill factsheet: relevant managed service providers, updated 3 Nov 2026, https://www.gov.uk/government/publications/cyber-security-and-resilience-network-and-information-systems-bill-factsheets/relevant-managed-service-providers

14 legislation.gov.uk, UK GDPR Article 5: principles, including storage limitation, https://www.legislation.gov.uk/eur/2016/679/article/5

15 legislation.gov.uk, UK GDPR Article 33: notification of a personal data breach, https://www.legislation.gov.uk/eur/2016/679/article/33

16 legislation.gov.uk, UK GDPR Article 28: processor, https://www.legislation.gov.uk/eur/2016/679/article/28

17 NCSC, Supply chain security guidance (12 principles), https://www.ncsc.gov.uk/collection/supply-chain-security



TRANSPUTEC

Know what your suppliers hold.

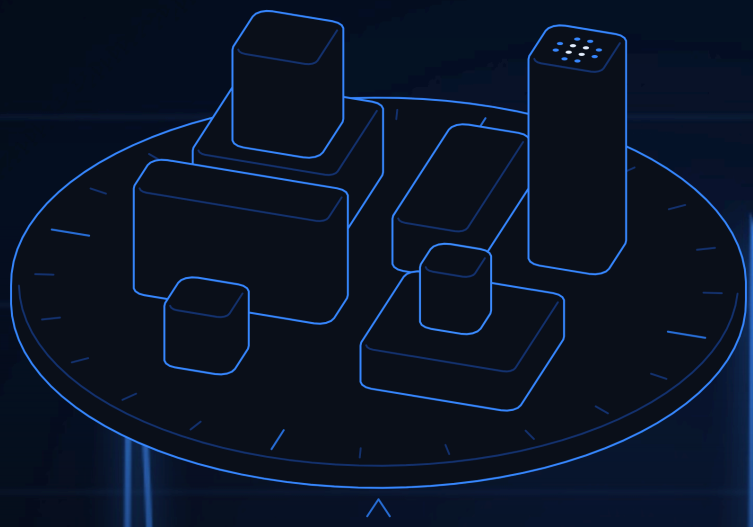
We help UK organisations map which suppliers hold their sensitive data, tighten contracts and access, and respond quickly when a supplier reports a breach.

Book a supplier risk review

transputec.com

PUT IT INTO PRACTICE

Companion playbook: Know who holds your data



PLAYBOOK NO. 14 · CYBER RISK IN BUSINESS TERMS

Count the cost.

Ahold Delhaize expects its October cyber incident to cut quarterly sales by up to €250 million. Here is how to put your own number on cyber risk, and use it.

INSIDE

Contents

How to put a business price on cyber risk, test it with finance, check your insurance, rank resilience spending by value and report it to the board, with a plan for this week, this month and this quarter.

Foreword 03

Introduction 04

01 Price the risk 06

02 Rehearse and insure 11

03 Invest and report 15

Sources 23

FOREWORD

Your cyber risk has a price. Most boards have never seen it.

On 4 November 2026 Ahold Delhaize, owner of Albert Heijn, Delhaize and Food Lion, said its October cyber incident is expected to reduce fourth-quarter net sales by €200 million to €250 million and operating income by €75 million to €100 million. The cost of the response and remediation itself, it said, would be marginal.[1]

That is the pattern of the biggest incidents of the last two years. Marks and Spencer, Co-op and Jaguar Land Rover each lost far more through disrupted trading than through IT recovery.[2,3,4] Yet most boards still see cyber risk as an IT budget line: tools, staff, perhaps a fine.

This playbook is about closing that gap. It shows how to express cyber risk as lost revenue per day, how to test it with finance, what to ask your insurer, how to rank resilience spending and how to report it so the board can make real decisions.



The Transputec team
Transputec

INTRODUCTION

Cyber risk is a trading risk.

The question that matters is not how much an attack would cost to clean up. It is how much trade you would lose while you cleaned it up, and how quickly you could get it back.



Measure in money

Express the risk as lost sales and margin per day of disruption, not as a heat map or a maturity score.



Rehearse with finance

Run outage scenarios with the people who own the numbers, so the estimate becomes a shared view.



Spend where it shortens downtime

Rank resilience investments by the days of disruption they avoid, multiplied by what a day costs.

The IT bill is the small one. The big one is the trade you cannot do.

Every major incident since 2025 has shown the same thing. The organisations that recover best know their number before they need it.

01

PART 01

Price the risk.

Turn a technical worry into a figure the board can weigh against other risks.

01 Why boards underestimate

02 Four questions that set the price

03 A simple cost model

04 Business impact analysis

WHY IT MATTERS

Why boards still underestimate cyber risk

> **Revenue stops when systems stop. Rent, wages and energy do not.**

Ask most boards what a serious cyber attack would cost and the answer starts with IT: forensic investigators, rebuilding servers, specialist lawyers, perhaps a regulatory fine. Those costs are real, but they are not where most of the money goes.

Ahold Delhaize is the latest example. It took systems offline to contain an incident in October, and expects to lose €200 million to €250 million of sales and €75 million to €100 million of operating income as a result. Response and remediation costs are expected to be marginal.[1]

M&S first estimated a £300 million hit to operating profit, against direct costs later put at about £136 million.[5,2] Co-op estimated £285 million of lost revenue.[3] JLR booked £196 million of cyber costs, while the Cyber Monitoring Centre estimated a £1.9 billion impact on the UK economy.[4,6]

The reason is simple arithmetic. When ordering, picking or production stops, revenue stops, but rent, wages and energy do not. Most of the lost revenue falls straight through to profit, and customers who go elsewhere do not all come back.

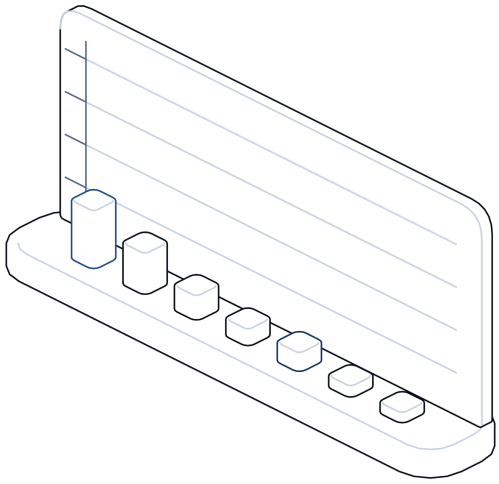
Few organisations measure this. In the government's 2025/26 survey, only 31% of UK businesses had board-level responsibility for cyber security and 25% had a formal incident response plan.[7] Self-reported costs were low, which tells you more about measurement than about risk.

The fix is not a new tool. It is a number: what a day without each critical service would cost. Once the board has that number, cyber decisions become ordinary business decisions about risk and return.

THE METHOD

Four questions that set the price

You do not need an actuarial model to start. You need honest answers to four questions for each critical service.



01 **What stops?**

List the services that take or fulfil orders, make products, pay people or serve customers, and the systems each depends on.

02 **For how long?**

Estimate a realistic outage, not a best case. Recent retail incidents ran from two weeks to more than six.

03 **What does a day cost?**

Lost sales by channel, lost margin, waste, compensation and extra staff costs, agreed with finance.

04 **What would shorten it?**

Tested backups, manual workarounds, segmented networks and rehearsed decisions. These become your investment list.

THE MODEL

A simple cost-of-downtime model

Six lines, each owned by someone who knows the numbers. Estimate a range for a two-week outage, not a single figure.

COST LINE	HOW TO ESTIMATE IT	OWNER
Lost sales	Average daily sales by channel times days disrupted, less sales that simply shift later.	Finance with sales
Lost margin	Lost sales times contribution margin, plus fixed costs that carry on regardless.	Finance
Supply chain and waste	Perishable or time-critical stock at risk, penalty clauses, partners who cannot operate.	Operations
Response and recovery	Forensics, rebuild, advisers and overtime. Ask your provider for realistic ranges.	IT lead
Customers and regulatory	Refunds, compensation, notification, legal advice and possible regulatory action.	Legal and customer
Insurance recovery	What the policy would actually pay after waiting periods and sub-limits.	Finance with broker

BUSINESS IMPACT ANALYSIS

A business impact analysis in six steps

Done properly once, then refreshed each year or after any major change.

01 **List critical services**

Start with the ten or so activities that earn revenue or keep you legal. Name an owner for each.

02 **Map dependencies**

For each service, record the systems, data, suppliers and people it needs.

03 **Set tolerances**

Agree how long each service can be down before damage becomes unacceptable.

04 **Cost the outage**

Use the six-line model to put a daily cost range on each service.

05 **Test the workarounds**

Check what can continue manually, for how long, and who knows how.

06 **Agree the gaps**

Where the tolerance is shorter than the realistic recovery time, you have an investment case.

02

PART 02

Rehearse and insure.

Test the number with the people who own it, then check who pays when it happens.

01 Running a scenario with finance

02 Three scenarios to borrow

03 Cyber insurance

SCENARIO EXERCISE

Running a scenario exercise with finance

Ministers asked leading UK companies in October 2025 to plan and exercise how they would keep operating and rebuild after a destructive incident.[8] This is how to do it in half a day.

Set the scenario

Core systems taken offline to contain an attack, for two weeks. Stores, sites and offices remain open.

Bring the numbers

Finance brings daily sales and margin by channel. Operations brings stock, staffing and supplier dependencies.

Run the clock

Walk through day one, day three, week one and week two. Record what keeps trading and what stops.

Find the gaps

Note missing workarounds, unclear decisions and suppliers you could not reach.

Agree actions

Turn each gap into an owned action with a date, and a revised cost estimate for the board.

> **Invite the finance director and the head of operations, not only IT. The exercise fails if no one in the room owns the numbers.**

THREE SCENARIOS

Three scenarios to borrow



RETAIL AND DISTRIBUTION

Ordering and warehouse systems offline for two weeks

WHAT STOPS

Online orders, replenishment, electronic pricing and loyalty. Stores open but shelves thin.

WHAT TO PRICE

Daily sales by channel, fresh waste, refunds for cancelled orders and overtime.

WORKAROUND TO TEST

Manual replenishment lists for core lines and a simple fallback for pricing.

BOARD NUMBER

Lost margin per day times realistic days to normal trading.



MANUFACTURING

Plant and planning systems shut down for checks

WHAT STOPS

Production scheduling, parts ordering, shipping documents and supplier payments.

WHAT TO PRICE

Lost output, idle labour, penalty clauses and support suppliers may need.

WORKAROUND TO TEST

Safe manual restart of priority lines and a paper process for dispatch.

BOARD NUMBER

Contribution lost per day plus supplier support, for three to six weeks.



PROFESSIONAL SERVICES

Email, documents and billing unavailable for a week

WHAT STOPS

Client work, deadlines, time recording and invoicing.

WHAT TO PRICE

Unbilled time, missed deadlines, client credits and delayed cash collection.

WORKAROUND TO TEST

A clean communication channel and access to critical documents offline.

BOARD NUMBER

Daily billable value at risk plus the cash flow delay.

03

Cyber insurance: read it against your scenario

A policy is only as useful as its fit with the outage you are most likely to suffer.

WHAT IT SHOULD COVER

Business interruption from your own outage, ideally a key supplier's too, plus response and legal costs.

WHAT TO CHECK

Waiting periods before interruption cover starts, sub-limits, how lost profit is calculated and any exclusions that could apply.

WHAT THE EVIDENCE SAYS

Only 10% of UK businesses hold a specific cyber policy.[7] M&S claimed its £100 million maximum against about £136 million of direct costs.[2]

WHAT GOOD LOOKS LIKE

Your modelled two-week loss sits next to the policy limit, and the board knows the gap it is carrying.

OWNER

Finance director, with the broker and IT lead

Bring this to the monthly review, with a date for each action.

03

PART 03

Invest and report.

Spend where it shortens downtime, and report risk in a language the board already uses.

01 Ranking resilience investments

02 Reporting to the board

03 Week, month and quarter

04 Pitfalls

PRIORITISE

Rank resilience spending by value

Plot each proposal by how much outage cost it avoids and how easily you can deliver it. Start top right.

↑ DOWNTIME COST AVOIDED

PLAN AND FUND

High value, harder

Network segmentation, rebuilding critical systems for faster recovery, a second route for key suppliers.

START HERE

High value, easier

Tested offline backups, manual workarounds for top services, strong sign-in for admins, NCSC Early Warning.

QUESTION IT

Low value, harder

Large tool purchases that do not shorten an outage or make one less likely in your scenario.

KEEP TIDY

Low value, easier

Housekeeping that helps but does not move the board number. Do it, but do not lead with it.

EASE TO DELIVER →

REPORTING

Five rules for reporting cyber risk to the board

The Cyber Governance Code of Practice asks boards to own cyber risk.[9] These rules give them something to own.

01 **Lead with money**

Show the estimated loss range for a plausible severe outage, by critical service.

02 **Show the trend**

Report whether that range is shrinking quarter by quarter, and why.

03 **Tie spending to days**

Every resilience proposal states the downtime it avoids and the value of those days.

04 **Report the tested, not the planned**

Restores, workarounds and exercises count only when they have been tried.

05 **Name the residual risk**

State the gap between modelled loss and insurance, and ask the board to accept or reduce it.

THE PLAN

This week, this month, this quarter

A realistic sequence for a mid-sized UK organisation. Larger groups run it per business unit.

WHEN	WHAT TO DO	OWNER
This week	Name the board sponsor. List the ten critical services and their system owners.	Chief executive
This week	Sign up to NCSC Early Warning. Confirm offline backups exist and when they were last restored.	IT lead
This month	Cost a two-week outage for each critical service with the six-line model.	Finance director
This month	Send the scenario to your broker and ask what the policy would pay.	Finance with broker
This quarter	Run a half-day scenario exercise with finance and operations. Agree owned actions.	Chief operating officer
This quarter	Present the loss range, gaps and ranked investments to the board.	Board sponsor

PITFALLS

Five ways cost estimates go wrong

Each makes the number look smaller than it is.

01 Counting only IT

Forensics and rebuilds are the visible part. Lost trading is usually larger.

02 Assuming a best-case outage

Plan for weeks, not days. Recent retail incidents took two weeks or more to contain.

03 Ignoring containment

Your own decision to switch systems off will stop trading. Price it in.

04 Forgetting suppliers

A supplier's outage can stop you just as surely as your own.

05 Trusting the policy limit

Waiting periods and sub-limits can leave a large gap. Read the wording.

REMEMBER

A number that is roughly right and owned by finance is worth more than a precise one nobody believes.

BEFORE YOU START

Questions for your board, suppliers and insurer

Ask them this month. Write down the answers and who gave them.

FOR THE BOARD

- ? What would a week without our core systems cost us in sales and margin?
- ? When did we last rehearse a destructive incident with finance in the room?
- ? Which resilience investment would shorten an outage most?

FOR SUPPLIERS AND THE INSURER

- ? How quickly could you restore the service we depend on, and have you tested it?
- ? Would you tell us within hours if you were attacked?
- ? What would our policy pay for a two-week outage, and after what wait?

CHECKLIST

Do you know your number?

Tick what is in place today. Anything blank is your next step.

- [ ] **A named board sponsor for cyber risk**
  With the authority to call an exercise.
- [ ] **Critical services listed with owners**
  And the systems each depends on.
- [ ] **A daily cost of downtime for each**
  Agreed with finance, as a range.
- [ ] **Tested offline backups**
  Restored within the last quarter.
- [ ] **Manual workarounds for top services**
  Written down and tried.
- [ ] **Insurance checked against the scenario**
  Waiting periods and sub-limits understood.
- [ ] **A scenario exercise in the last 12 months**
  With finance and operations present.

GLOSSARY

Words worth knowing

Business impact analysis

A structured look at which services matter most, what they depend on and what an outage would cost.

Business interruption cover

Insurance that pays for lost profit and extra costs while operations are disrupted.

Containment

Action to stop an attack spreading, often by taking systems offline.

Contribution margin

Revenue minus the costs that vary with sales. The profit lost when a sale is lost.

Cost of downtime

Lost sales, lost margin and extra costs for each day a service is unavailable.

Early Warning

A free NCSC service that alerts organisations to potential attacks on their networks.

Impact tolerance

The longest a service can be disrupted before the harm becomes unacceptable.

Offline backup

A copy of data kept where an attacker on your network cannot reach or change it.

Scenario exercise

A structured rehearsal of an incident, run in real time or step by step.

Waiting period

The time an insurance policy requires before interruption cover starts to pay.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 Ahold Delhaize, Q3 2026 results and updated 2026 guidance reflecting cybersecurity incident, 4 Nov 2026, https://newsroom.aholddelhaize.com/ahold-delhaize-reports-resilient-q3-2026-results-and-updates-2026-guidance-to-reflect-business-disruption-caused-by-recent-cybersecurity-incident/

2 The Register, M&S pegs cyberattack cleanup costs, 5 Nov 2025, https://theregister.com/2025/11/05/ms_pegs_cyberattack_cleanup_costs/

3 Co-op, Co-op navigates headwinds and looks forward with confidence, clarity and purpose, 26 Mar 2026, https://www.co-operative.coop/media/news-releases/co-op-navigates-headwinds-and-looks-forward-with-confidence-clarity-and

4 JLR, JLR performance impacted in challenging quarter, 14 Nov 2025, https://media.jlr.com/corporate/news/2025/11/jlr-performance-impacted-challenging-quarter

5 The Register, M&S cyberattack disruption (fiscal 2025 results), 21 May 2025, https://www.theregister.com/2025/05/21/ms_cyberattack_disruption/

6 The Record, Jaguar Land Rover cyberattack economic impact, 22 Oct 2025, https://therecord.media/jaguar-land-rover-cyberattack-economic-impact

7 DSIT, Cyber security breaches survey 2025/2026, 30 Apr 2026, https://www.gov.uk/government/statistics/cyber-security-breaches-survey-20252026/cyber-security-breaches-survey-20252026

8 GOV.UK, Ministerial letter on cyber security to leading UK companies, 13 Oct 2025, https://www.gov.uk/government/publications/ministerial-letter-on-cyber-security-to-leading-uk-companies/ministerial-letter-on-cyber-security

9 techUK, Government publishes Cyber Governance Code of Practice, 8 Apr 2025, https://www.techuk.org/insights/news/government-publishes-cyber-governance-code-of-practice

TRANSPUTEC

Know your number before you need it.

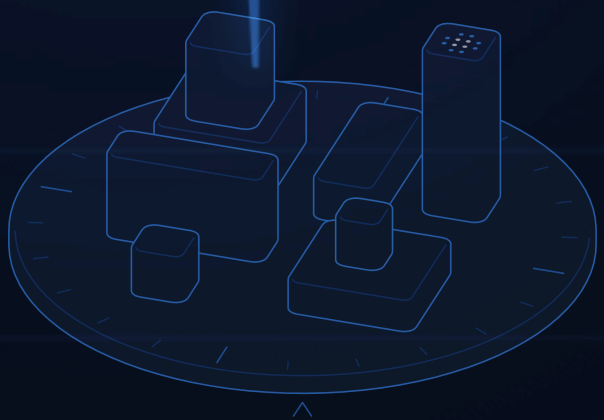
Transputec helps UK organisations put a price on cyber risk, rehearse how they would keep trading through an outage and invest where it shortens downtime most.

Book a cyber resilience review

transputec.com

READ THE COMPANION REPORT

Companion report · The €250 Million Question





INTELLIGENCE REPORT · THE BUSINESS COST OF CYBER INCIDENTS

The €250 million question.

Ahold Delhaize expects its October cyber incident to cut fourth-quarter sales by up to €250 million, while the cost of the IT response is marginal. What that tells boards about where cyber losses really come from.

INSIDE

Contents

An evidence-based look at the Ahold Delhaize cyber incident of October 2026, how it compares with Marks and Spencer, Co-op and Jaguar Land Rover, where the money is really lost, and what UK boards should do now.

Executive summary 03

Key findings 04

At a glance 05

Timeline 06

01 Anatomy of a loss 07

02 Not the first time 11

03 What it means for UK organisations 15

Sources 21

EXECUTIVE SUMMARY

The IT bill was marginal. The trading bill was up to €250 million.

On Sunday 11 October 2026, Ahold Delhaize, owner of Albert Heijn, Delhaize, Food Lion and Stop & Shop, began taking systems offline after a cybersecurity incident.[1,2] Online ordering stopped in the Netherlands and the United States, several Dutch distribution centres halted and some Albert Heijn shelves emptied.[3]

On 4 November the company said the incident is expected to cut fourth-quarter net sales by €200 million to €250 million and operating income by €75 million to €100 million. In the same statement it said incremental response and remediation costs would have only a marginal impact on its 2026 results.[4]

That contrast is the story, and it is not new. Marks and Spencer first expected a £300 million hit to operating profit, against direct costs it later put at about £136 million.[5,6] Co-op estimated £285 million of lost revenue.[7] Jaguar Land Rover booked £196 million of cyber costs, while an independent estimate put the cost to the UK economy at £1.9 billion.[8,9]

Most cyber risk models still start with the IT bill: forensics, rebuilding, legal fees, perhaps a fine. Those costs are real, but in each case above they were the smaller part. The larger part is trade that never happens while systems are down, and the margin that goes with it.

THE BOTTOM LINE

Price cyber risk in lost trading days, not IT invoices. A board that knows what a week without its core systems would cost, and has rehearsed working through it, will spend its security budget better.

KEY FINDINGS

Seven things the evidence shows

01 **The headline figure is a range, and an estimate.**

Ahold Delhaize gave €200 million to €250 million of lost fourth-quarter sales "based on current estimations". Up to €250 million is the top of that range.[4]

02 **Lost trade dwarfed the response bill.**

The company expects €75 million to €100 million less operating income, while response and remediation costs are described as marginal.[4]

03 **Containment caused much of the damage.**

The company took systems offline to protect its environment, which stopped online orders and, in the Benelux, parts of the supply chain.[4,10]

04 **Two weeks was enough to move a full-year forecast.**

Most disruption was contained within two weeks, yet guidance for underlying earnings per share growth fell from mid-to-high single digits to low single digits.[4]

05 **UK retail saw the same shape in 2025.**

M&S lost 46 days of online orders, and Co-op estimated £285 million of lost revenue after restricting its own systems.[11,7]

06 **The wider economy pays too.**

The Cyber Monitoring Centre estimated the JLR incident cost the UK £1.9 billion and affected over 5,000 organisations, mostly through lost manufacturing output.[9,12]

07 **Most UK boards are not set up to see this.**

Only 31% of UK businesses have board-level responsibility for cyber security, and 25% have a formal incident response plan.[13]

AT A GLANCE

The numbers behind the story

Ahold Delhaize's figures are the company's current estimates and may change when it reports full-year results.

€200m to €250m

Expected reduction in Ahold Delhaize's fourth-quarter 2026 net sales from the October incident.[4]

€75m to €100m

Expected reduction in underlying and IFRS operating income from the same incident.[4]

2 weeks

Time the company says it took to contain most of the disruption. Full restoration was still under way on 4 November.[4]

£285m

Co-op's unaudited estimate of the direct revenue impact of its 2025 cyber attack.[7]

£1.9bn

Cyber Monitoring Centre estimate of the UK economic impact of the 2025 JLR incident.[9]

25%

UK businesses with a formal incident response plan, in the government's 2025/26 survey.[13]

TIMELINE

Three weeks from switch-off to price tag

The Ahold Delhaize incident as reported by the company and the Dutch and UK press.

11 Oct 2026 — **Systems go offline**

Ahold Delhaize detects suspicious activity and begins taking systems offline on Sunday afternoon.[1,2]

12 Oct — **Online services down on two continents**

Albert Heijn, Etos and Gall & Gall websites and apps go down. US chain websites, including Stop & Shop and Food Lion, follow.[1]

13 Oct — **No evidence of data theft so far**

The company says it has found no evidence that customer, employee or partner data was stolen. Several distribution centres have stopped.[3]

15 Oct — **Distribution resumes**

Dutch distribution centres are operating again and regular deliveries to stores restart nationwide.[2]

18 Oct — **Police report and websites back**

The company files a police report, having notified the Dutch NCSC within 24 hours. Albert Heijn's website and app return.[10,2]

23 Oct — **Home deliveries restart**

Albert Heijn begins restarting online grocery deliveries after cancelling orders up to 22 October.[2]

4 Nov — **The cost is published**

Third-quarter results put the expected hit at €200 million to €250 million of sales and €75 million to €100 million of operating income.[4]

01

PART 01

Anatomy of a loss.

What happened at Ahold Delhaize, what the company has said, and what it has not.

01 What happened

02 The outlook, before and after

03 How downtime becomes lost sales

WHAT HAPPENED

Two weeks offline, one quarter dented

> **The bills most people picture when they think of a cyber attack were the marginal part.**

Ahold Delhaize is one of the largest food retailers in the world, with more than 9,000 supermarkets in nine countries.[14] Its brands include Albert Heijn in the Netherlands, Delhaize in Belgium, and Food Lion, Stop & Shop, Giant Food and Hannaford in the United States. It has been here before: a November 2024 incident disrupted some US brands, and the company later confirmed files had likely been taken.[15]

The trouble began on the afternoon of Sunday 11 October.[1] The company described a cybersecurity incident, brought in external experts and took certain systems offline.[3] Within a day Dutch and US websites and apps were down.

The effects reached the shop floor. Several Dutch distribution centres stopped, fresh products ran short, and for nearly two weeks electronic shelf labels could not always show correct prices.[3,16] Stores stayed open. Distribution centres were running again by 15 October, but home deliveries did not restart until 23 October.[2]

On the nature of the attack the company has said little. It called it a malicious action by third parties and filed a police report on 18 October.[10] It has not said whether ransomware was involved, and no group has been confirmed as responsible. In mid-October it had found no evidence of data theft.[3] We do not speculate beyond that.

The numbers came on 4 November: €200 million to €250 million less fourth-quarter net sales, €75 million to €100 million less operating income, and a lower full-year outlook.[4] The chief executive said most of the disruption was contained within two weeks, but that work to fully restore normal operations continues.

One line in the release deserves more attention than it got. Incremental response and remediation costs, the bills most people picture when they think of a cyber attack, are expected to have a marginal impact on 2026 operating income.[4] The money was lost at the till and in the supply chain.

BEFORE AND AFTER

How the 2026 outlook changed

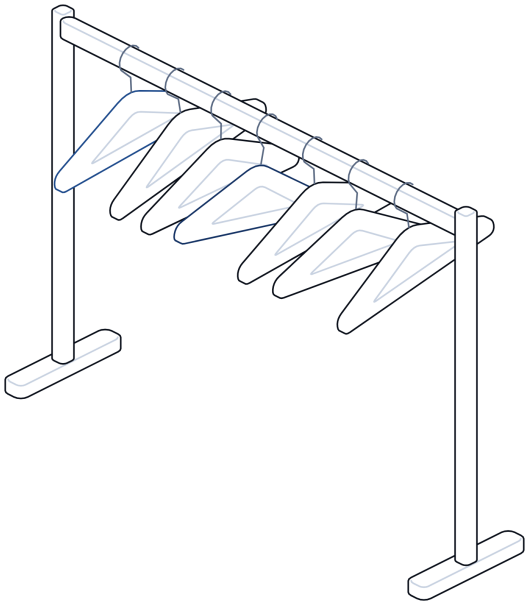
Ahold Delhaize's guidance before and after the incident. All figures are from the company's third-quarter release.[4]

MEASURE	BEFORE	AFTER, 4 NOV 2026
Q4 net sales	No incident effect.	Reduced by €200m to €250m, on current estimates.
Q4 operating income	No incident effect.	Reduced by €75m to €100m, underlying and IFRS.
Underlying operating margin	Around 4.0%.	Approaching 4.0%.
Underlying EPS growth	Mid to high single digits.	Low single digits.
Free cash flow	At least €2.3bn.	Around €2.1bn, also reflecting new Serbian supplier payment rules.
Response and remediation	Not applicable.	Marginal impact on 2026 IFRS operating income.

HOW IT WORKS

How downtime becomes lost sales

A ransom or a rebuild is not where most of the money goes. This is the chain that turns days offline into a hole in the quarter.



01 **Containment switches things off**

Taking systems offline limits the attacker but also stops ordering, picking and pricing. It is usually the right call, and it has a price.

02 **Dependent processes stall**

Distribution, replenishment and online fulfilment run on shared systems. When they stop, stock stops moving and shelves thin.

03 **Customers go elsewhere**

Cancelled deliveries and gaps on the shelf send shoppers to competitors. Some of that trade does not come back.

04 **Fixed costs keep running**

Rent, wages and energy continue while sales fall, so much of the lost revenue drops straight through to profit.

02

PART 02

Not the first time.

Marks and Spencer, Co-op and Jaguar Land Rover show the same pattern: the trading loss is the big number.

01 Four incidents side by side

02 Where the money really goes

03 The four lines of cost

COMPARISON

Four incidents, one pattern

Figures are company estimates unless stated. Measures differ between companies, so compare the shape, not the totals.

INCIDENT	DISRUPTION	TRADING IMPACT	DIRECT AND IT COSTS
Ahold Delhaize, Oct 2026	Systems offline from 11 Oct; most disruption contained in two weeks.[4]	€200m to €250m lower Q4 sales; €75m to €100m lower operating income.	Response and remediation: marginal impact.
M&S, Apr 2025	Online orders paused for 46 days.[11]	Initial estimate of about £300m off operating profit, before mitigation.[5]	About £136m direct costs; £100m maximum insurance claim.[6]
Co-op, Apr 2025	Systems restricted; food availability reduced.[17]	£285m direct revenue impact; £107m impact to profitability (unaudited).[7]	Underlying operating loss includes an estimated £86m direct cyber impact.
JLR, Sep 2025	Global systems shut down; phased restart from 8 Oct.[8]	Q2 revenue down 24% to £4.9bn, also reflecting tariffs and the Jaguar wind-down.	£196m of cyber costs booked as exceptional items.
UK economy, JLR	Over 5,000 UK organisations affected.[9]	£1.9bn estimated impact, mostly lost manufacturing output.[12]	Category 3 of 5 on the Cyber Monitoring Centre scale.

ANALYSIS

Where the money really goes

> **Each euro of lost sales cost Ahold Delhaize roughly 37 to 40 cents of operating income.**

Put the four incidents side by side and a pattern appears. The costs that sit naturally with IT, such as forensics, rebuilding systems and specialist advice, are significant but bounded. The costs that sit with the business, lost sales, wasted stock, lost margin and the knock-on to partners, are larger and harder to cap.

M&S is the clearest example because it reported both. In May 2025 it expected the attack to reduce operating profit by about £300 million before mitigation.[5] Six months later it put total direct costs at about £136 million, of which £83 million was systems response and recovery, and claimed the £100 million maximum on its cyber insurance. UK online sales fell 42.9% in the half.[6]

Co-op shows the cost of containment. Its food business was hit hardest, with availability reduced as systems were proactively taken offline.[17] By March 2026 it put the direct revenue impact at £285 million and the impact on profitability at £107 million, figures it described as unaudited.[7]

JLR shows how far the damage travels. The company booked £196 million of cyber costs and arranged a £500 million supplier financing scheme and a £1.5 billion loan guaranteed by UK Export Finance.[8] The Cyber Monitoring Centre put the UK impact at £1.9 billion, mostly lost output at JLR and its suppliers.[9,12]

Ahold Delhaize fits the same shape. On our calculation from its own ranges, each euro of lost sales cost roughly 37 to 40 cents of operating income.[4] That is roughly nine to ten times the group's operating margin of around 4%, because rent, wages and energy carry on when the tills go quiet.

The lesson is not that IT costs are trivial. It is that a risk model built on IT costs alone will understate the exposure by a wide margin, and will steer investment towards tools rather than towards the ability to keep trading.

COST LINES

The four lines of cost

Every major incident produces costs in four places. Most risk registers count only the third.

Lost trading

Sales that do not happen while ordering, picking or production is down. Usually the largest line, and the least modelled.

Supply chain and waste

Stock that cannot move, fresh food written off, and partners and suppliers who cannot operate.

Response and recovery

Forensics, rebuild, specialist advisers and overtime. Real money, but usually the smaller part.

Customers, legal and regulatory

Refunds and compensation for cancelled orders, legal advice, and regulatory exposure if personal data is involved.

Ask finance to estimate each line for a two-week outage. The first line is usually the biggest and the least understood.

03

PART 03

What it means for the UK.

UK boards have been asked, in writing, to plan for destructive incidents. Few have put a price on one.

01 The UK picture

02 What boards count, and what they miss

03 Recommendations

THE UK PICTURE

Asked to plan, still not pricing

> **What is not measured tends not to be funded.**

The UK has had its own warnings. The NCSC handled 204 nationally significant incidents in the year to August 2025, up from 89 the year before, and 18 were highly significant.[18] Its chief executive said cyber security is now a matter of business survival.

In October 2025 ministers, the NCSC and the National Crime Agency wrote to the chief executives and chairs of leading UK companies, including the FTSE 350. They asked boards to use the Cyber Governance Code of Practice, join the NCSC's Early Warning service and require Cyber Essentials in their supply chains, and to plan and exercise how they would continue operations and rebuild after a destructive incident.[19]

That last request is the one the Ahold Delhaize figures speak to. Continuing operations is a business problem, not an IT one. It depends on whether stores, warehouses and service teams can keep working in some reduced form while core systems are rebuilt.

The evidence suggests many organisations are not there yet. The government's 2025/26 survey found board-level responsibility for cyber security in 31% of businesses and a formal incident response plan in 25%. Some 47% had cyber insurance of some kind, but only 10% held a specific cyber policy, and 15% reviewed risks from their immediate suppliers.[13]

Self-reported costs in the same survey are low, with a median of zero for the most disruptive breach.[13] That is not proof that incidents are cheap. It suggests most organisations do not measure the cost of disruption, and what is not measured tends not to be funded.

The Cyber Governance Code, published in April 2025, gives boards a structure built on five principles: risk management, strategy, people, incident planning, response and recovery, and assurance and oversight.[20] What most boardrooms still lack is a number: what a week without core systems would cost.

THE BLIND SPOT

What boards count, and what they miss

Most cyber risk reporting stops at the left-hand column. The money is in the right-hand one.

COST LINE	WHAT IS USUALLY COUNTED	WHAT IS USUALLY MISSED
Downtime	Time to restore IT systems.	Lost sales per day, per channel, until normal trading returns.
Supply chain	Rarely counted at all.	Stock that cannot move, perishable waste, partners who cannot trade.
Margin	Revenue at risk, if anything.	Fixed costs that continue, so most lost revenue falls to profit.
Customers	Notification costs after a data breach.	Compensation, lost loyalty and customers who switch and stay away.
Insurance	The headline policy limit.	Waiting periods, sub-limits and how business interruption is calculated.
Recovery	When systems come back.	When normal trading comes back, which can be weeks later.

RECOMMENDATIONS

Six things boards should do now

Each one turns cyber risk from a technical worry into a business number the board can act on.

01 **Put a price on a day of downtime**

Work with finance to estimate lost sales and margin per day for each critical service, and use it in every cyber investment decision.

02 **Run a business impact analysis, not just an IT one**

Map which processes stop when which systems stop, and how long each can survive on manual workarounds.

03 **Exercise with finance and operations in the room**

Rehearse a two-week outage. Record what keeps trading, what stops and what it costs.

04 **Read the insurance policy against the scenario**

Compare your modelled loss with the limits, waiting periods and sub-limits. Know the gap you are carrying.

05 **Rank resilience spending by value**

Prioritise what shortens an outage or keeps trading going, measured in days avoided times cost per day.

06 **Report cyber risk in money**

Replace traffic lights with ranges: the loss from a plausible severe scenario, and what reduces it.

FOR THE BOARD

Questions to ask at the next meeting

If the answers are not to hand, that is the finding.

EXPOSURE

- ? What would a week without our core systems cost in lost sales and margin?
- ? Which processes stop first, and how long can each run manually?
- ? Which suppliers could halt our trading if they were hit?

READINESS

- ? When did we last rehearse a destructive incident with finance and operations present?
- ? What would our cyber insurance actually pay for a two-week outage?
- ? How would we explain the cost to investors, customers and staff?

GLOSSARY

Words worth knowing

Business impact analysis

A structured look at which processes matter most, what they depend on and what an outage of each would cost.

Business interruption cover

Insurance that pays for lost profit and extra costs while operations are disrupted.

Containment

Action to stop an attack spreading, often by taking systems or connections offline.

Cost of downtime

Lost sales, lost margin and extra costs for each day a service is unavailable.

Cyber Governance Code of Practice

UK government guidance, published in April 2025, setting out what boards should do about cyber risk.

Early Warning

A free NCSC service that alerts organisations to potential attacks on their networks.

Operating income

Profit from trading before interest and tax. Ahold Delhaize reports underlying and IFRS measures.

Ransomware

Malicious software that encrypts or steals data so criminals can demand payment.

Recovery time objective

The maximum time a service can be down before the damage becomes unacceptable.

Waiting period

The time an insurance policy requires before business interruption cover starts to pay.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 DutchNews, Albert Heijn and sister chains abroad hit by likely cyberattack, 13 Oct 2026, https://www.dutchnews.nl/2026/10/albert-heijn-and-sister-chains-abroad-hit-by-likely-cyberattack/

2 IBTimes UK, Supermarket cyber incident leaves online shoppers facing at least 11 days without deliveries, Oct 2026, https://www.ibtimes.co.uk/albert-heijn-deliveries-resume-after-cyber-incident-1826826

3 NL Times, Albert Heijn parent Ahold Delhaize finds no evidence of data theft after cyber incident, 13 Oct 2026, https://nltimes.nl/2026/10/13/albert-heijn-parent-ahold-delhaize-finds-evidence-data-theft-cyber-incident

4 Ahold Delhaize, Ahold Delhaize reports resilient Q3 2026 results and updates 2026 guidance to reflect business disruption caused by recent cybersecurity incident, 4 Nov 2026, https://newsroom.aholddelhaize.com/ahold-delhaize-reports-resilient-q3-2026-results-and-updates-2026-guidance-to-reflect-business-disruption-caused-by-recent-cybersecurity-incident/

5 The Register, M&S cyberattack disruption (fiscal 2025 results), 21 May 2025, https://www.theregister.com/2025/05/21/ms_cyberattack_disruption/

6 The Register, M&S pegs cyberattack cleanup costs, 5 Nov 2025, https://theregister.com/2025/11/05/ms_pegs_cyberattack_cleanup_costs/

7 Co-op, Co-op navigates headwinds and looks forward with confidence, clarity and purpose, 26 Mar 2026, https://www.co-operative.coop/media/news-releases/co-op-navigates-headwinds-and-looks-forward-with-confidence-clarity-and

8 JLR, JLR performance impacted in challenging quarter, 14 Nov 2025, https://media.jlr.com/corporate/news/2025/11/jlr-performance-impacted-challenging-quarter

9 The Record, Jaguar Land Rover cyberattack economic impact, 22 Oct 2025, https://therecord.media/jaguar-land-rover-cyberattack-economic-impact

10 NOS, Moederbedrijf Albert Heijn doet na ruim een week aangifte van cyberaanval, 19 Oct 2026, https://nos.nl/artikel/2635852-moederbedrijf-albert-heijn-doet-na-ruim-een-week-aangifte-van-cyberaanval

11 ESM Magazine (Reuters), M&S resumes online orders after 46-day cyberattack pause, 10 Jun 2025, https://www.esmmagazine.com/technology/ms-resumes-online-orders-after-46-day-cyberattack-pause-290083

12 Infosecurity Magazine, JLR hack UK's costliest ever, hitting economy with £1.9bn loss, 22 Oct 2025, https://www.infosecurity-magazine.com/news/jlr-hack-uk-costliest-ever-19bn/

SOURCES

Sources and notes

Sources continued.

13 DSIT, Cyber security breaches survey 2025/2026, 30 Apr 2026, https://www.gov.uk/government/statistics/cyber-security-breaches-survey-20252026/cyber-security-breaches-survey-20252026

14 NOS, Ahold Delhaize ziet schade van tientallen miljoenen door cyberaanval, 4 Nov 2026, https://nos.nl/artikel/2637977-ahold-delhaize-ziet-schade-van-tientallen-miljoenen-door-cyberaanval

15 SecurityWeek, Ahold Delhaize confirms data stolen in ransomware attack, 18 Apr 2025, https://www.securityweek.com/ahold-delhaize-confirms-data-stolen-in-ransomware-attack/

16 NL Times, Cyberattack cost Albert Heijn parent Ahold Delhaize estimated €250 million, 4 Nov 2026, https://nltimes.nl/2026/11/04/cyberattack-cost-albert-heijn-parent-ahold-delhaize-estimated-eu250-million

17 The Record, Cyberattack on British retailer the Co-op shaved about $275 million from revenues, 25 Sep 2025, https://therecord.media/retailer-the-co-op-cyberattack-lost-revenue

18 NCSC, UK experiencing four 'nationally significant' cyber attacks every week, 14 Oct 2025, https://www.ncsc.gov.uk/news/uk-experiencing-four-nationally-significant-cyber-attacks-weekly

19 GOV.UK, Ministerial letter on cyber security to leading UK companies, 13 Oct 2025, https://www.gov.uk/government/publications/ministerial-letter-on-cyber-security-to-leading-uk-companies/ministerial-letter-on-cyber-security

20 techUK, Government publishes Cyber Governance Code of Practice, 8 Apr 2025, https://www.techuk.org/insights/news/government-publishes-cyber-governance-code-of-practice



TRANSPUTEC

Know your number before you need it.

Transputec helps UK organisations put a price on cyber risk, test how they would keep trading through an outage and invest where it shortens downtime most.

Book a cyber resilience review

transputec.com

PUT IT INTO PRACTICE

Playbook No. 14 · Count the Cost: the companion playbook

TRANSPUTEC



HOT TOPICS · EU AI ACT

Ready for the AI Act.

Brussels moved some of the AI Act's deadlines, but not all of them. A practical playbook for UK organisations that sell into the EU, use AI tools sold there, or simply want to get AI governance right.

INSIDE

Contents

A practical guide for UK organisations to the EU AI Act after the Digital Omnibus: which deadlines moved, which did not, and what to do this week, this month and this quarter.

Foreword 03

Introduction 04

01 What changed 06

02 Know your AI 10

03 Plan and govern 16

Questions to ask 21

Checklist 22

Sources 24

FOREWORD

The deadline moved. The work did not.

In July 2026 the EU changed the timetable of its Artificial Intelligence Act. The Digital Omnibus on AI pushed the main obligations for high-risk AI systems back from August 2026 to December 2027, and for AI built into regulated products to August 2028. Headlines read it as a pause.

It was not a pause. The bans on certain AI practices have applied since February 2025. Rules for general-purpose AI models have applied since August 2025. Transparency duties, such as telling people they are talking to a chatbot and labelling deepfakes, started in August 2026, and a short grace period for marking AI-generated content ends on 2 December 2026. New bans on AI that creates non-consensual intimate images start the same day.

For UK organisations the Act matters more than its location suggests. It applies to anyone placing AI on the EU market, and to UK firms whose AI output is used in the EU. Many of the AI tools UK teams use every day are built to meet it. The UK itself has taken a different route, with existing regulators applying five principles and no AI bill in the May 2026 King's Speech.[1,2] This playbook sets out what actually changed, what you need to know about the AI you build and buy, and a timeline-based plan you can start this week.



The Transputec team
Transputec

INTRODUCTION

Three questions decide how much of the AI Act lands on you.

You do not need to read 400 pages of regulation to know where you stand. You need honest answers to three questions, kept up to date.

What AI do we have?

A single register of the AI systems you build, buy and use, including the AI features switched on inside software you already pay for.

What role do we play?

For each system, are you the provider who puts it on the market, or the deployer who uses it? The duties are very different.

How risky is each use?

Banned, high-risk, transparency only, or minimal. The category sets both the obligations and the deadline.

The high-risk deadline moved by sixteen months. Most of the other deadlines did not move at all.

Use the extra time to build the inventory, the documentation and the supplier evidence that high-risk compliance needs. Do not use it as a reason to stop.

01

PART 01

What changed.

The Digital Omnibus on AI is now law. Here is what it moved, what it added and what it left alone.

01 The new timetable

02 Old dates against new

03 Why the UK should care

WHAT CHANGED

A new clock for high-risk AI, and the same clock for everything else

> **Annex III moved to December 2027. Bans, general-purpose AI rules and transparency duties did not wait.**

The Digital Omnibus on AI is Regulation (EU) 2026/1744. It was signed on 8 July 2026, published in the Official Journal on 24 July and entered into force on the third day after publication.[3] The European Commission lists 27 July 2026 as its entry into force.[4] It is adopted law, not a proposal.

Its headline change is timing. The requirements for high-risk AI systems listed in Annex III, which covers uses such as recruitment, education, credit scoring and access to essential services, now apply from 2 December 2027 instead of 2 August 2026. High-risk AI that is part of products covered by EU safety law, such as machinery or medical devices, follows from 2 August 2028.[3]

The reason given in the regulation is practical: harmonised standards and guidance arrived late, and many national authorities were not ready.[3] The obligations themselves were not rewritten. Risk management, data governance, technical documentation, human oversight and conformity assessment are all still coming.[5]

What did not move matters as much. Prohibited practices and the AI literacy duty have applied since 2 February 2025, and the rules for general-purpose AI models since 2 August 2025.[6] Transparency duties under Article 50 have applied since 2 August 2026. The Omnibus only gave providers of generative AI systems already on the market before that date until 2 December 2026 to add machine-readable marking to their output.[3,5]

The Omnibus also added. From 2 December 2026 it bans AI systems that generate non-consensual intimate images or child sexual abuse material, and it softened the AI literacy duty: organisations must now take measures to support AI literacy rather than ensure a sufficient level of it.[3]

Some things are still not settled. The Commission's guidelines on classifying high-risk systems were published as a draft in May 2026 and are not final.[7] A separate Digital Omnibus on data and privacy rules remains a proposal. Treat anything still in draft as direction of travel, not law.

WHAT CHANGED

Old dates against new

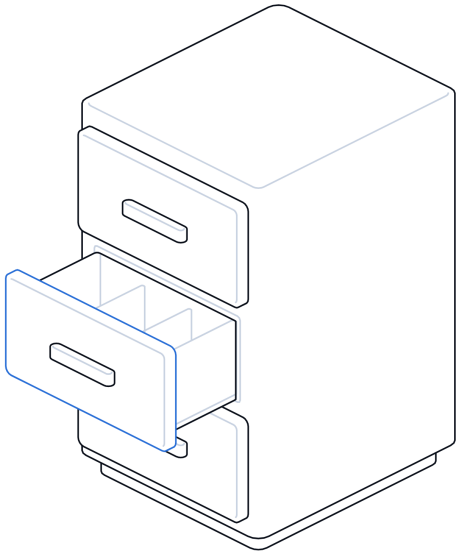
The AI Act's main application dates after Regulation (EU) 2026/1744. Status is adopted law unless marked otherwise.

OBLIGATION	ORIGINAL DATE	DATE NOW
Prohibited practices, AI literacy	2 February 2025	Unchanged. Literacy duty reworded from July 2026.
General-purpose AI models	2 August 2025	Unchanged. Commission fining powers from 2 August 2026.
Article 50 transparency	2 August 2026	Unchanged. Marking grace to 2 December 2026 for older generative systems.
New bans: intimate images, CSAM	Not in original Act	2 December 2026.
High-risk, Annex III uses	2 August 2026	2 December 2027.
High-risk, Annex I products	2 August 2027	2 August 2028.

WHAT CHANGED

Why a UK organisation is in scope

The AI Act follows the AI into the EU market, not the company's address. Four common routes bring UK firms within reach.[6]



01 **You sell AI into the EU**

Providers placing AI systems on the EU market are covered wherever they are based. High-risk providers outside the EU must appoint an EU authorised representative.

02 **Your AI's output is used in the EU**

UK providers and deployers are covered where the output of their AI system is used in the Union, for example scoring EU applicants.

03 **You run operations in the EU**

An EU subsidiary or branch using AI is a deployer established in the Union, with deployer duties.

04 **Your suppliers are in scope**

Even where you are not, the AI tools you buy are being built to the Act. Their documentation, labels and limits will reach you through contracts.

02

PART 02

Know your AI.

An inventory, a risk category and a clear role for every system. Everything else follows from these.

01 Build the inventory

02 Sort by risk

03 Provider or deployer

04 Transparency and literacy

KNOW YOUR AI

Build an AI inventory in five steps

Expect to find more AI than you think. Tie the register to procurement and change control so new AI cannot arrive unseen.

01 Ask every team, not just IT

Run a short survey: which tools, which features, what data goes in, what decisions come out. Include free tools and browser extensions.

02 Check the software you already own

CRM, HR, finance and productivity suites now ship AI features. Record which are switched on and who switched them on.

03 Record the facts for each system

Supplier, purpose, users, data, people affected, EU link, and whether output reaches customers.

04 Assign a role and a risk category

Provider or deployer; prohibited, high-risk, transparency or minimal. Send uncertain cases for legal review.

05 Give each entry an owner and a review date

A named business owner, not IT alone. Review quarterly and whenever a supplier adds an AI feature.

KNOW YOUR AI

Four risk tiers, four sets of duties

A first sort for your inventory. Final classification of borderline high-risk cases needs legal input.

TIER	EXAMPLES	WHAT IT MEANS	WHEN
Prohibited	Social scoring, manipulative techniques, untargeted facial image scraping, workplace emotion recognition.	Stop and remove. Fines up to EUR 35m or 7% of turnover.	Since Feb 2025
High-risk	CV screening, worker monitoring, credit scoring, exam marking, access to essential services.	Risk management, documentation, oversight, logging, registration.	Dec 2027 (Annex III)
Transparency	Chatbots, image, audio or video generators, deepfakes, AI-written public-interest text.	Tell people, mark output, label deepfakes.	Since Aug 2026
Minimal	Spam filters, spelling tools, internal summarising with human review.	No specific duties. Literacy and good practice still apply.	Now
GPAI models	Large models offered to others to build on.	Documentation, copyright policy, training content summary.	Since Aug 2025

KNOW YOUR AI

Provider or deployer

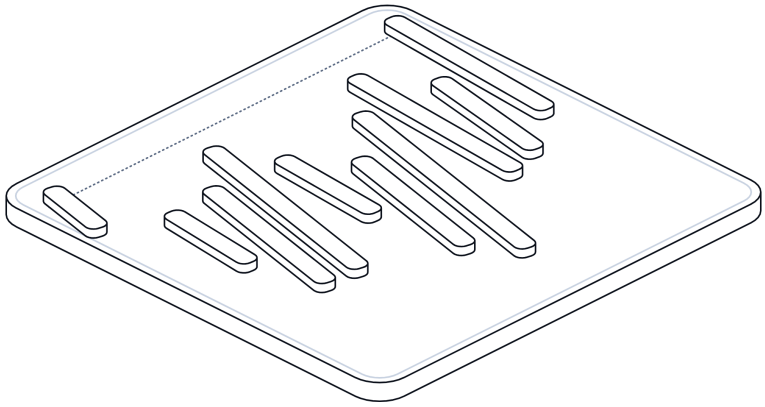
Most UK organisations are deployers. Some become providers without realising it.[6]

TOPIC	PROVIDER (BUILDS OR BRANDS IT)	DEPLOYER (USES IT)
Who	Develops an AI system, or has one developed, and places it on the market under its own name.	Uses an AI system under its authority in the course of its work.
High-risk duties	Risk management, data governance, technical documentation, conformity assessment, CE marking, registration.	Use per instructions, competent human oversight, relevant input data, monitoring, incident reporting.
Transparency	Design chatbots to disclose they are AI; mark generated content machine-readably.	Label deepfakes and AI-written public-interest text; disclose emotion recognition.
Role switch	Stays provider unless another party takes over the role.	Becomes a provider if it rebrands, substantially modifies or repurposes a system into high-risk use.
UK angle	Non-EU high-risk providers need an EU authorised representative.	Covered where established in the EU or where output is used there.

KNOW YOUR AI

Transparency and labelling

Article 50 has applied since 2 August 2026. The marking grace period for generative systems already on the market ends on 2 December 2026.[3]



01 **Tell people they are talking to AI**

Chatbots and voice agents must disclose they are AI unless it is obvious. Check every customer-facing assistant, including supplier-hosted ones.

02 **Mark generated content**

Providers of systems that generate text, images, audio or video must mark output in a machine-readable, detectable way. Ask your suppliers how they do it.

03 **Label deepfakes and public-interest text**

Deployers must disclose deepfakes and AI-written text published to inform the public, unless a person with editorial responsibility has genuinely reviewed it.[8]

04 **Use the code and the icons**

The Commission's voluntary Code of Practice, finalised in June 2026, and its EU icon set give a recognised way to show compliance.[9]

01

AI literacy: lighter wording, same good sense

The duty has applied since February 2025. The Omnibus changed it to taking measures to support AI literacy, without guaranteeing any individual's level.[3]

WHAT IT ASKS

Providers and deployers take measures to support AI literacy of staff and others using AI on their behalf, suited to their role and context.

WHAT GOOD LOOKS LIKE

Short role-based training, a plain-English AI policy, and guidance on checking output, protecting data and spotting misuse.

WHAT TO RECORD

Who was trained, on what, and when. Keep it with your AI inventory so you can show the link between tools and training.

COMMON MISTAKE

One generic e-learning module for everyone. Recruiters using screening tools need different guidance from marketers using image generators.

OWNER

HR and the AI programme owner

Bring this to the monthly review, with a date for each action.

03

PART 03

Plan and govern.

Documentation, supplier evidence and a governance rhythm, laid out against the dates that matter.

01 A governance loop

02 Documentation that earns its keep

03 Three UK cases

04 The timeline plan

PLAN AND GOVERN

A governance loop that fits on one page

Light enough for a mid-sized firm, solid enough to grow into ISO/IEC 42001 if you choose to certify.

Own

Name an accountable executive and an AI programme owner. Agree who can approve new AI use.

Assess

Classify each new system before go-live: role, risk tier, data, people affected, EU link.

Document

Keep the evidence the tier requires: purpose, instructions, oversight, testing, supplier documents.

Monitor

Watch performance, complaints and incidents. Review high-risk and customer-facing systems quarterly.

Improve

Feed lessons into policy, training and procurement. Report to the board twice a year.

> **ISO/IEC 42001 is a management system standard for AI. The first AI Act harmonised standard, EN 18286, is designed to sit on top of it.**[10]

PLAN AND GOVERN

Documentation that earns its keep

Records you will need for the Act, and that also help procurement, audit and incident response.

AI register

Every system, owner, role, risk tier, supplier, EU link and review date. The spine of everything else.

Use-case assessment

One or two pages per material system: purpose, data, people affected, risks, controls and sign-off.

Oversight plan

Who reviews output, what they check, when they can stop the system, and how decisions are logged.

Supplier evidence

Instructions for use, transparency features, marking approach, conformity status and incident contacts.

> If you might be a provider of a high-risk system, start technical documentation now. It takes longer than any other part.

PLAN AND GOVERN

Three UK organisations, three different positions

RECRUITMENT FIRM

CV screening for EU clients

THEIR ROLE

Deployer of a supplier's screening tool, filling roles in Ireland.

RISK TIER

High-risk (employment, Annex III). Deployer duties from 2 December 2027.

DO NOW

Get the supplier's instructions for use. Train recruiters who review rankings.

WATCH OUT

Rebranding or repurposing the tool could make the firm a provider.

SOFTWARE COMPANY

Generative assistant sold to EU customers

THEIR ROLE

Provider of a generative AI system sold in the EU.

RISK TIER

Transparency. Marking for versions sold before August 2026 due by 2 December 2026.

DO NOW

Confirm machine-readable marking and chatbot disclosure against the Code of Practice.

WATCH OUT

A significant redesign can end the grace period.

RETAILER

AI images and copy in marketing

THEIR ROLE

Deployer of generative tools for UK and EU campaigns.

RISK TIER

Transparency. Deepfake labelling in force since 2 August 2026.

DO NOW

Set a labelling rule for realistic synthetic people. Brief agencies.

WATCH OUT

Borderline edits need judgement; record each decision.

PLAN AND GOVERN

The timeline plan

Work back from the dates that are fixed in law. Owners are suggestions; adapt them to your structure.

WHEN	ACTIONS	OWNER
This week	Name an AI owner. Check for prohibited uses. List customer-facing chatbots and generative tools.	COO or CIO
This month	Complete the inventory and first risk sort. Send supplier questions. Publish an AI use policy.	AI owner, procurement
By 2 Dec 2026	Confirm content marking from generative suppliers. Labelling rules live. Check the new bans.	Marketing, product
This quarter	Role-based literacy training. Use-case assessments for material systems. Board briefing.	HR, AI owner
2027	Build high-risk evidence: oversight, logs, supplier documentation. Track final guidelines.	Risk, legal, IT
By 2 Dec 2027	Annex III high-risk systems compliant as provider or deployer.	Accountable executive

QUESTIONS TO ASK

For the board, and for every AI supplier

Clear answers to these show whether you are ready. Vague ones show where to start.

FOR THE BOARD

- ? Do we have a complete, owned register of the AI we build, buy and use?
- ? Which of our AI uses touch the EU, and in which role: provider or deployer?
- ? Are any of our uses high-risk, and are we building the evidence for December 2027?

FOR AI SUPPLIERS

- ? How does your product mark AI-generated content, and have you signed the Commission's Code of Practice?
- ? Is the system high-risk under the AI Act, and will you give us instructions for use and oversight guidance?
- ? Who is your EU authorised representative, and how will you tell us about incidents and material changes?

CHECKLIST

Are you ready for the AI Act?

Tick what is in place today. Anything left blank is your next step.

- [ ] **A named owner for AI governance**
  With authority to approve or stop new AI use.

- [ ] **A current AI register**
  Including AI features inside existing software.

- [ ] **Role and risk tier recorded for each system**
  Borderline high-risk cases sent for legal review.

- [ ] **No prohibited practices in use**
  Checked against Article 5, including the new bans from 2 December 2026.

- [ ] **Transparency in place**
  Chatbot disclosure, content marking from suppliers, deepfake labelling rules.

- [ ] **Role-based AI literacy measures**
  With records of who was trained and when.

- [ ] **Supplier questions sent and answered**
  Evidence filed with the register.

This checklist is a practical guide, not legal advice. Take advice on classification of specific systems.

GLOSSARY

Words worth knowing

AI system

A machine-based system that infers from inputs how to generate outputs such as predictions, content, recommendations or decisions.

Provider

The organisation that develops an AI system or model, or has it developed, and places it on the market under its own name.

Deployer

An organisation using an AI system under its authority, other than for personal non-professional use.

High-risk AI system

A system in an Annex III use, such as recruitment or credit, or a safety component of a regulated product.

General-purpose AI model

A model trained on broad data that can perform a wide range of tasks and be built into other systems.

Article 50

The AI Act's transparency duties: chatbot disclosure, marking generated content, labelling deepfakes.

Digital Omnibus on AI

Regulation (EU) 2026/1744, which amended the AI Act's timetable and some duties in July 2026.

Authorised representative

An EU-based party a non-EU provider of high-risk AI must appoint by written mandate.

Harmonised standard

A European standard cited in the Official Journal that gives a presumption of conformity.

ISO/IEC 42001

The international management system standard for AI, usable as the backbone of AI governance.

SOURCES

Sources and notes

Sources were accessed in November 2026. Dates and statuses were checked against EUR-Lex and the European Commission. This playbook is general guidance, not legal advice.

1 GOV.UK, A pro-innovation approach to AI regulation: government response, 6 February 2024, https://www.gov.uk/government/consultations/ai-regulation-a-pro-innovation-approach-policy-proposals/outcome/a-pro-innovation-approach-to-ai-regulation-government-response

2 IAPP, King's Speech signals diffuse UK digital policy agenda, but no AI bill, 14 May 2026, https://iapp.org/news/a/king-s-speech-signals-diffuse-uk-digital-policy-agenda-but-no-ai-bill

3 EUR-Lex, Regulation (EU) 2026/1744 (Digital Omnibus on AI), OJ L 24 July 2026, https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng

4 European Commission, AI Act: regulatory framework for AI, updated 19 October 2026, https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

5 Freshfields, EU AI Act unpacked #34: the final Digital Omnibus on AI, 10 July 2026, https://www.freshfields.com/en/our-thinking/blogs/technology-quotient/eu-ai-act-unpacked-34-the-final-digital-omnibus-on-ai-key-amendments-to-the-a-102nber

6 EUR-Lex, Regulation (EU) 2024/1689 (Artificial Intelligence Act), OJ L 12 July 2024, https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng

7 European Commission, Draft guidelines on the classification of high-risk AI systems, 19 May 2026, https://digital-strategy.ec.europa.eu/en/library/draft-commission-guidelines-classification-high-risk-ai-systems

8 Paul, Weiss, EU finalises transparency rules for AI-generated content, 4 August 2026, https://www.paulweiss.com/insights/client-memos/eu-finalises-transparency-rules-for-ai-generated-content

9 European Commission, Code of Practice on marking and labelling of AI-generated content, 2026, https://digital-strategy.ec.europa.eu/en/policies/code-practice-ai-generated-content

10 European Commission, First harmonised standard supporting the AI Act published in the Official Journal, 19 October 2026, https://digital-strategy.ec.europa.eu/en/library/first-harmonised-standard-supporting-ai-act-published-official-journal

TRANSPUTEC

Want a clear view of your AI estate?

Transputec helps UK organisations find the AI they already use, sort it by risk, put sensible governance around it and ask suppliers the right questions.

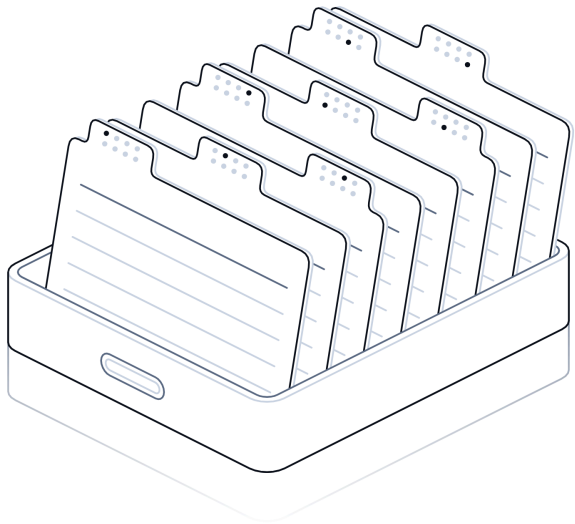
Book an AI governance review

transputec.com

READ THE COMPANION REPORT

The AI Act's New Clock · Intelligence report No. 15, the companion report





INTELLIGENCE REPORT · EU AI ACT

The AI Act's new clock.

The Digital Omnibus pushed back the AI Act's high-risk rules. Bans, general-purpose AI rules and transparency duties kept their dates. What changed, what did not, and what UK organisations should do now.

INSIDE

Contents

An evidence-based look at the EU AI Act after the Digital Omnibus on AI: which deadlines moved, which did not, what is still only draft or proposal, and what it means for UK organisations.

Executive summary 03

Key findings 04

Timeline 06

01 What changed 07

02 What did not change 11

03 The UK view 15

Recommendations 19

Sources 22

EXECUTIVE SUMMARY

The high-risk deadline moved. The rest of the Act kept running.

In July 2026 the EU amended its Artificial Intelligence Act through the Digital Omnibus on AI, Regulation (EU) 2026/1744.[1] The main obligations for high-risk AI systems in Annex III uses such as recruitment, credit and education now apply from 2 December 2027 instead of 2 August 2026. Those for AI in regulated products move to 2 August 2028.[1]

Much of the Act did not move. Prohibited practices have applied since February 2025, rules for general-purpose AI models since August 2025, and the Article 50 transparency duties since 2 August 2026.[2,3] The date many reports give for transparency, 2 December 2026, is narrower than it sounds: it ends a grace period for machine-readable marking by generative AI systems already on the market before August 2026, and it is the start date of new bans on AI that creates non-consensual intimate images or child sexual abuse material.[1]

UK organisations are in scope when they place AI on the EU market or when their AI's output is used in the EU.[2] The UK has chosen a different, principles-based path and has no AI bill before Parliament.[4,5] For many UK firms the Act will arrive through suppliers and customers as much as through regulators.

This report separates adopted law from guidance, drafts and proposals, explains what the change means in practice and sets out recommendations for UK boards and IT leaders.

THE BOTTOM LINE

Use the extra sixteen months to build the inventory, documentation and supplier evidence high-risk compliance needs. Meanwhile, treat the bans, transparency duties and AI literacy as live today, and finish the December 2026 items now.

KEY FINDINGS

Seven things the evidence shows

01 **The delay is law, not a proposal.**

Regulation (EU) 2026/1744 was published on 24 July 2026 and the Commission records it in force from 27 July 2026.[1,6]

02 **Only the high-risk requirements moved.**

Sections 1 to 3 of Chapter III now apply from 2 December 2027 for Annex III uses and 2 August 2028 for Annex I products. The content of the duties is unchanged.[1,3]

03 **Transparency started in August 2026.**

Article 50 applies from 2 August 2026. Only Article 50(2) marking for generative systems already on the market gained time, to 2 December 2026.[1]

04 **The Omnibus added as well as delayed.**

New bans on AI that generates non-consensual intimate imagery or child sexual abuse material apply from 2 December 2026.[1]

05 **AI literacy was softened, not removed.**

Providers and deployers must now take measures to support AI literacy, without guaranteeing any individual's level.[1]

06 **Key guidance is still unfinished.**

The high-risk classification guidelines remain a draft, and only one harmonised standard, for quality management, has been cited.[7,8]

07 **UK firms are exposed through the market, not the map.**

The Act reaches providers placing AI on the EU market and UK providers or deployers whose output is used in the EU.[2]

AT A GLANCE

The new clock, in six figures

Each figure comes from the amended text of the AI Act or the European Commission.

2 Dec 2027

High-risk obligations for Annex III uses such as recruitment, credit and education. Previously 2 August 2026.[1]

2 Aug 2028

High-risk obligations for AI in products under EU safety law, listed in Annex I. Previously 2 August 2027.[1]

2 Dec 2026

End of the Article 50(2) marking grace period for older generative systems, and start of the new bans.[1]

2 Aug 2030

Deadline for high-risk systems intended for use by public authorities, including those already in service.[1]

EUR 15m / 3%

Maximum fine for breaching Article 50 transparency or deployer duties, whichever is higher. Prohibited practices: EUR 35m or 7%.[2]

1

Harmonised standard cited so far: EN 18286, on quality management, published in mid-October 2026.[8,9]

TIMELINE

From the original Act to the new clock

Key dated events. All entries are adopted measures or published documents unless marked as draft.

1 Aug 2024

AI Act enters into force

Regulation (EU) 2024/1689 sets a staged timetable running to August 2027.[2]

2 Feb 2025

Bans and AI literacy apply

Chapters I and II apply, including prohibited practices and the literacy duty.[2]

2 Aug 2025

General-purpose AI rules apply

Obligations for GPAI model providers and the governance framework apply.[2,6]

19 Nov 2025

Commission proposes the Digital Omnibus

Proposal COM(2025) 836 on AI, alongside a separate proposal on data, privacy and cyber rules.[10,11]

7 May 2026

Political agreement

Parliament and Council negotiators agree the AI Omnibus; on 19 May the Commission publishes draft high-risk guidelines.[6,7]

16 to 29 Jun 2026

Formal adoption

Parliament adopts on 16 June; the Council gives final approval on 29 June. The transparency Code of Practice is finalised on 10 June.[3,10,12]

24 to 27 Jul 2026

Published and in force

Regulation (EU) 2026/1744 appears in the Official Journal; final Article 50 guidelines follow on 20 July.[1,6,13]

2 Aug 2026

Transparency and GPAI enforcement

Article 50 applies, and the Commission's fining powers for GPAI providers become available.[14]

Mid Oct 2026

First harmonised standard

EN 18286 on quality management is cited in the Official Journal.[8,9]

01

PART 01

What changed.

A sixteen-month reprieve for high-risk AI, a short grace for content marking, and some new bans.

01 Why the dates moved

02 Before and after

03 How the grace periods work

WHAT CHANGED

Why Brussels moved the clock, and why it fixed the new dates

> **The adopted text replaced a sliding start date with fixed ones. A known deadline is easier to plan for than a moving one.**

The Digital Omnibus on AI is explicit about its reason. The regulation says the late arrival of standards, common specifications and guidance, and the delayed setting up of national competent authorities, put the original 2 August 2026 date for high-risk rules at risk and threatened a significant rise in implementation costs.[1]

That was a fair description of the position. By mid-2026 no harmonised standard supporting the Act had been cited. The first, EN 18286 on quality management, only reached the Official Journal in October 2026, and it covers one requirement of many.[8] Without standards, providers of high-risk systems had no presumption of conformity to work towards.

The Commission's original proposal of November 2025 tried to link the start of high-risk duties to a Commission decision that support measures were available, with long-stop dates of 2 December 2027 and 2 August 2028.[11] The adopted text dropped that sliding mechanism and simply fixed the long-stop dates in law.[1] For businesses that is more useful: a known date beats a moving one.

The substance of the high-risk regime was not reopened. Risk management, data governance, technical documentation, logging, human oversight, accuracy and robustness, and conformity assessment all remain.[3] Deployer duties under Article 26 sit in the same part of the Act, so they move to December 2027 too.[1,2]

The Omnibus also adjusted the edges. A new category of small mid-cap companies, with fewer than 750 staff, receives SME-style relief including simplified documentation and lower penalty caps.[15] Providers and deployers may process special category data to detect and correct bias where strictly necessary, with safeguards. National regulatory sandboxes must be running by 2 August 2027.[1]

The pattern is familiar from other EU digital laws: legislators protect the political settlement and adjust the timetable when the supporting machinery runs late. The lesson for organisations is to plan to the adopted dates, not to hope for another delay.

WHAT CHANGED

Before and after the Omnibus

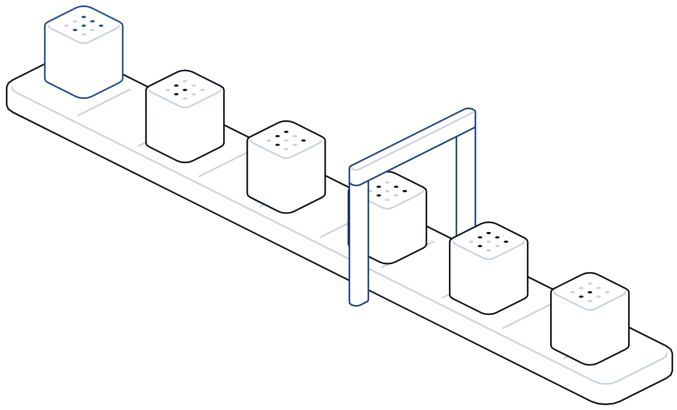
Main changes to the AI Act made by Regulation (EU) 2026/1744. All rows are adopted law.[1]

PROVISION	BEFORE	AFTER
Annex III high-risk	Applied from 2 August 2026.	Applies from 2 December 2027. Requirements unchanged.
Annex I high-risk	Applied from 2 August 2027.	Applies from 2 August 2028.
Article 50(2) marking	Applied from 2 August 2026 to all.	Generative systems on the market before 2 August 2026 have until 2 December 2026.
Prohibited practices	Eight categories since February 2025.	Adds non-consensual intimate imagery and CSAM generation from 2 December 2026.
AI literacy	Ensure, to their best extent, a sufficient level.	Take measures to support AI literacy. No guaranteed level.
Bias detection data	Special category data allowed for high-risk providers.	Open to providers and deployers of all AI systems where strictly necessary.

WHAT CHANGED

How the grace periods work

The amended Article 111 decides which existing systems must change, and when.[1]



01 **Legacy high-risk systems**

High-risk systems placed on the market before the new dates are caught only if their design changes significantly afterwards. The first unit of a type and model sets the date.

02 **Public authorities**

Existing high-risk systems intended for public authorities must comply by 2 August 2030, even without design changes.

03 **Generative content marking**

Generative AI systems on the market before 2 August 2026 have until 2 December 2026 to mark output machine-readably under Article 50(2).

04 **General-purpose AI models**

Models placed on the market before 2 August 2025 must comply by 2 August 2027, under the original Act.[2]

02

PART 02

What did not change.

Bans, general-purpose AI rules and most transparency duties kept their dates. Some of the guidance is still unfinished.

01 What applies today

02 Headlines against the law

03 Adopted, draft or proposed

WHAT DID NOT CHANGE

Four obligations that are already live

> **The December 2026 date ends one narrow grace period. It does not mark the start of transparency.**

The first is the list of prohibited practices. Since 2 February 2025 the Act has banned AI used for social scoring, manipulative or exploitative techniques that cause significant harm, untargeted scraping of facial images, and emotion recognition in workplaces and schools, among others.[2] Breaches carry the Act's highest fines: up to EUR 35 million or 7% of worldwide turnover.[2]

The second is the regime for general-purpose AI models. Providers have had obligations on documentation, copyright policy and training content summaries since August 2025, and the Commission's power to fine them became available on 2 August 2026.[14] Models already on the market before August 2025 must comply by August 2027.[2]

The third is transparency. Since 2 August 2026, providers must design chatbots so people know they are dealing with AI, and must mark generated audio, images, video and text in a machine-readable way. Deployers must label deepfakes and AI-generated text published to inform the public on matters of public interest.[13] The Commission published final guidelines on 20 July 2026, and its voluntary Code of Practice, with an EU icon set for labels, was finalised in June.[6,12]

The Article 50(2) grace period is the source of the widely reported December date. It covers only machine-readable marking, and only generative systems already on the market before 2 August 2026.[1] Chatbot disclosure and deepfake labelling were not deferred.[3]

The fourth is AI literacy. The Omnibus softened the wording, but the duty to take measures supporting staff AI literacy still applies to every provider and deployer, whatever their risk tier.[1]

What most organisations get wrong is to read the headline delay as covering everything. Firms that paused AI governance work after July 2026 may already be behind on transparency, and may not know whether their marketing, customer service or product teams are using AI in ways the Act now governs.

WHAT DID NOT CHANGE

Headlines against the law

Common readings of the change, checked against the amended text.

CLAIM	WHAT IS SAID	WHAT THE LAW SAYS
The AI Act is delayed	The Act has been pushed back to 2027.	Only high-risk requirements moved. Bans, GPAI and transparency apply now.[1]
Transparency starts in December	Labelling duties begin on 2 December 2026.	Article 50 applies from 2 August 2026. December ends a marking grace for older generative systems.
Literacy was scrapped	The AI literacy duty was removed.	It was reworded to require supporting measures. It still applies.[1]
Deployers can wait	Users of AI have nothing to do until 2027.	Deployers have transparency, literacy and prohibition duties today. High-risk deployer duties follow in 2027.
It does not touch the UK	The Act is an EU matter.	It reaches UK providers selling into the EU and output used in the EU.[2]

WHAT DID NOT CHANGE

Adopted, final, draft or proposed

The status of the main instruments as of November 2026. Only adopted law creates obligations; guidance shows how regulators will read it.

INSTRUMENT	STATUS	WHAT IT MEANS
Regulation (EU) 2026/1744	Adopted law, in force since July 2026.	The new dates are binding.[1]
Article 50 guidelines	Final, July 2026. Not binding.	The Commission's reading of transparency scope and exceptions.[13]
Transparency Code of Practice	Final, June 2026. Voluntary.	A recognised route to show Article 50 compliance.[12]
EN 18286 standard	Cited in the Official Journal, October 2026.	Presumption of conformity for quality management only.[8]
High-risk classification guidelines	Draft, May 2026.	Direction of travel. Examples may change before adoption.[7]
Digital Omnibus on data and privacy	Proposal, still under negotiation.	Proposed GDPR changes are not law. Current rules apply.[3,11]

03

PART 03

What it means for the UK.

No AI Act at home, but plenty of the EU's Act at the border, in contracts and in the tools UK teams use.

01 How UK firms are caught

02 Four exposure profiles

03 Two approaches side by side

THE UK VIEW

Outside the EU, but not outside the Act

> **Most UK firms will meet the AI Act through their suppliers and customers before they meet a regulator.**

The AI Act follows AI into the EU market. It applies to providers placing AI systems or general-purpose models on the EU market wherever they are established, and to providers and deployers in third countries where the output of their AI system is used in the Union.[2] A UK software firm selling an AI feature to EU customers, or a UK recruiter scoring candidates for EU roles, can be inside its scope.

Providers outside the EU that offer high-risk systems must appoint an authorised representative in the Union by written mandate.[2] For UK firms that is a contract, a cost and a lead time to plan before December 2027, not after.

Most UK organisations will feel the Act indirectly. The AI products they buy from global vendors are being built to meet it, so instructions for use, content marking and transparency features will arrive whether or not the buyer is in scope. Contracts with EU customers will increasingly ask UK suppliers to confirm their role and their compliance.

The UK has taken a different route. Its 2024 response to the AI regulation white paper set five cross-sector principles for existing regulators to apply within their remits, on a non-statutory footing.[4] The January 2025 AI Opportunities Action Plan focused on growth and adoption.[16] The King's Speech of May 2026 contained no AI bill.[5]

That does not leave UK firms without rules. Data protection law already governs much AI use, and the Data (Use and Access) Act 2025 reformed the rules on automated decision-making.[17] Sector regulators expect firms to manage AI risk within existing duties.

The practical answer for most UK organisations is one governance approach that meets the stricter regime where it applies and good practice everywhere else. Running separate UK and EU programmes for the same tools doubles the effort and invites gaps.

THE UK VIEW

Four exposure profiles

Where a UK organisation sits decides how much of the Act applies, and when.

Selling AI into the EU

Provider duties. Transparency now; high-risk from December 2027 with an EU authorised representative; marking by 2 December 2026 for older generative products.

Output used in the EU

Scoring, screening or generating content for EU people or customers. Check whether the use is high-risk and who the provider is.

Operating in the EU

EU subsidiaries and branches are deployers established in the Union, with transparency, literacy and future high-risk duties.

Buying AI products

Not directly in scope for UK-only use, but suppliers' documentation, labels and limits will shape contracts and controls.

Many organisations fit more than one profile. Classify each AI system, not the company as a whole.

THE UK VIEW

Two approaches side by side

How the UK and EU regimes compare for an organisation deciding where to set its bar.

TOPIC	EU AI ACT	UK APPROACH
Legal basis	A single horizontal regulation with direct effect.[2]	Existing law plus five non-statutory principles.[4]
Risk tiers	Prohibited, high-risk, transparency, minimal; separate GPAI rules.	No statutory tiers. Regulators judge risk in context.
Enforcement	National authorities and the Commission's AI Office; fines up to 7%.	Existing regulators within their remits, such as data protection and financial services.
Timetable	Staged dates to 2028, and 2030 for public authority systems.	No AI-specific compliance dates. No AI bill in the 2026 King's Speech.[5]
Practical bar	Mandatory where in scope.	A useful benchmark for good governance.

RECOMMENDATIONS

Six steps for UK organisations

In order of urgency. Each builds evidence you will need whichever regime applies.

01 **Build and own an AI register now**

Every system built, bought or used, with role, risk tier, EU link and a named business owner.

02 **Close the December 2026 items**

Confirm generative suppliers mark content, check for the new prohibited uses, and put deepfake labelling rules in place.

03 **Treat high-risk as a 2027 project starting today**

Classify borderline cases with legal input, appoint an EU representative if needed and start documentation.

04 **Put the Act into supplier contracts**

Ask for role, risk tier, instructions for use, marking approach, incident contacts and change notices.

05 **Make AI literacy role-based and recorded**

Different guidance for recruiters, marketers, developers and approvers, with training records kept.

06 **Choose a management system**

Use ISO/IEC 42001 as the governance backbone; EN 18286 is built to sit on top of it for high-risk providers.[8]

QUESTIONS FOR BOARDS

Questions for the board

Ask these at the next meeting. The answers show whether the organisation has used the extra time or lost it.

EXPOSURE

- ? Which of our AI systems touch the EU market, and are we provider or deployer for each?
- ? Do any of our uses fall into Annex III high-risk categories?
- ? Who is accountable for AI governance, and what has changed since July 2026?

READINESS

- ? Are our chatbot disclosures, content marking and deepfake labels in place today?
- ? What evidence do our AI suppliers give us, and is it in our contracts?
- ? How do we know staff using AI have the guidance their role needs?

GLOSSARY

Terms used in this report

AI Act

Regulation (EU) 2024/1689, the EU's horizontal law on AI systems and general-purpose AI models.

Digital Omnibus on AI

Regulation (EU) 2026/1744, which amended the AI Act's timetable and some duties from July 2026.

Annex III

The list of high-risk use areas, such as employment, education, credit and essential services.

Annex I

EU product safety laws whose products can contain high-risk AI as a safety component.

Provider

The organisation that develops an AI system or model and places it on the market under its own name.

Deployer

An organisation using an AI system under its authority in a professional context.

Article 50

Transparency duties: chatbot disclosure, machine-readable marking, deepfake and public-interest text labelling.

Grace period

Extra time for systems already on the market before a new rule applies, set out in Article 111.

Harmonised standard

A European standard cited in the Official Journal that gives a presumption of conformity.

Small mid-cap

A company that is not an SME, has fewer than 750 staff and meets turnover or balance sheet limits.

SOURCES

Sources and notes

Sources were accessed in November 2026. Primary legal texts were checked on EUR-Lex. Law firm commentary is used for dates and context not stated in official pages.

1 EUR-Lex, Regulation (EU) 2026/1744 (Digital Omnibus on AI), OJ L 24 July 2026, https://eur-lex.europa.eu/eli/reg/2026/1744/oj/eng

2 EUR-Lex, Regulation (EU) 2024/1689 (Artificial Intelligence Act), OJ L 12 July 2024, https://eur-lex.europa.eu/eli/reg/2024/1689/oj/eng

3 Freshfields, EU AI Act unpacked #34: the final Digital Omnibus on AI, 10 July 2026, https://www.freshfields.com/en/our-thinking/blogs/technology-quotient/eu-ai-act-unpacked-34-the-final-digital-omnibus-on-ai-key-amendments-to-the-a-102nber

4 GOV.UK, A pro-innovation approach to AI regulation: government response, 6 February 2024, https://www.gov.uk/government/consultations/ai-regulation-a-pro-innovation-approach-policy-proposals/outcome/a-pro-innovation-approach-to-ai-regulation-government-response

5 IAPP, King's Speech signals diffuse UK digital policy agenda, but no AI bill, 14 May 2026, https://iapp.org/news/a/king-s-speech-signals-diffuse-uk-digital-policy-agenda-but-no-ai-bill

6 European Commission, AI Act: regulatory framework for AI, updated 19 October 2026, https://digital-strategy.ec.europa.eu/en/policies/regulatory-framework-ai

7 European Commission, Draft guidelines on the classification of high-risk AI systems, 19 May 2026, https://digital-strategy.ec.europa.eu/en/library/draft-commission-guidelines-classification-high-risk-ai-systems

8 European Commission, First harmonised standard supporting the AI Act published in the Official Journal, 19 October 2026, https://digital-strategy.ec.europa.eu/en/library/first-harmonised-standard-supporting-ai-act-published-official-journal

9 CEN-CENELEC, First ever European standard on AI published in the OJEU, 15 October 2026, https://www.cencenelec.eu/news-events/news/2026/en-in-the-spotlight/2026-10-15-en-18286-2026-published-in-ojeu/

SOURCES

Sources and notes

Sources continued. This report is general analysis, not legal advice.

10 European Parliament, Legislative resolution of 16 June 2026 on the Digital Omnibus on AI, P10_TA(2026)0198, https://data.europarl.europa.eu/distribution/doc/TA-10-2026-0198_en.pdf

11 Sidley Austin, EU Digital Omnibus: the Commission proposes important changes to the EU's digital rulebook, 9 December 2025, https://datamatters.sidley.com/2025/12/09/eu-digital-omnibus-the-european-commission-proposes-important-changes-to-the-eus-digital-rulebook/

12 European Commission, Code of Practice on marking and labelling of AI-generated content, 2026, https://digital-strategy.ec.europa.eu/en/policies/code-practice-ai-generated-content

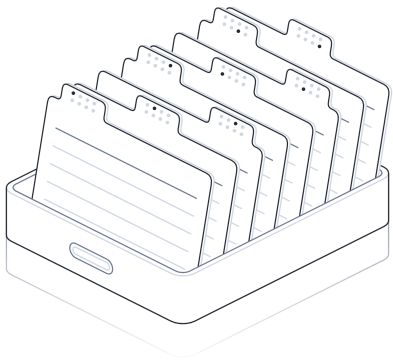
13 Paul, Weiss, EU finalises transparency rules for AI-generated content, 4 August 2026, https://www.paulweiss.com/insights/client-memos/eu-finalises-transparency-rules-for-ai-generated-content

14 Mayer Brown, EU AI Act news: Digital Omnibus on AI, new guidance on risk classification, GPAI and transparency, 30 July 2026, https://www.mayerbrown.com/en/insights/publications/2026/07/eu-ai-act-news-digital-omnibus-on-ai-new-guidance-on-risk-classification-gpai-and-transparency-obligations

15 Orrick, EU AI Act update: Digital Omnibus finalizes 8 compliance changes, 29 July 2026, https://www.orrick.com/en/Insights/2026/07/EU-AI-Act-Update-Digital-Omnibus-Finalizes-8-Compliance-Changes

16 GOV.UK, AI Opportunities Action Plan, 13 January 2025, https://www.gov.uk/government/publications/ai-opportunities-action-plan

17 legislation.gov.uk, Data (Use and Access) Act 2025, section 80 (automated decision-making), https://www.legislation.gov.uk/ukpga/2025/18/contents



TRANSPUTEC

Turn the new clock into a plan.

Transputec helps UK organisations map the AI they build and use, classify it against the AI Act, set up proportionate governance and hold suppliers to account.

Book an AI governance review

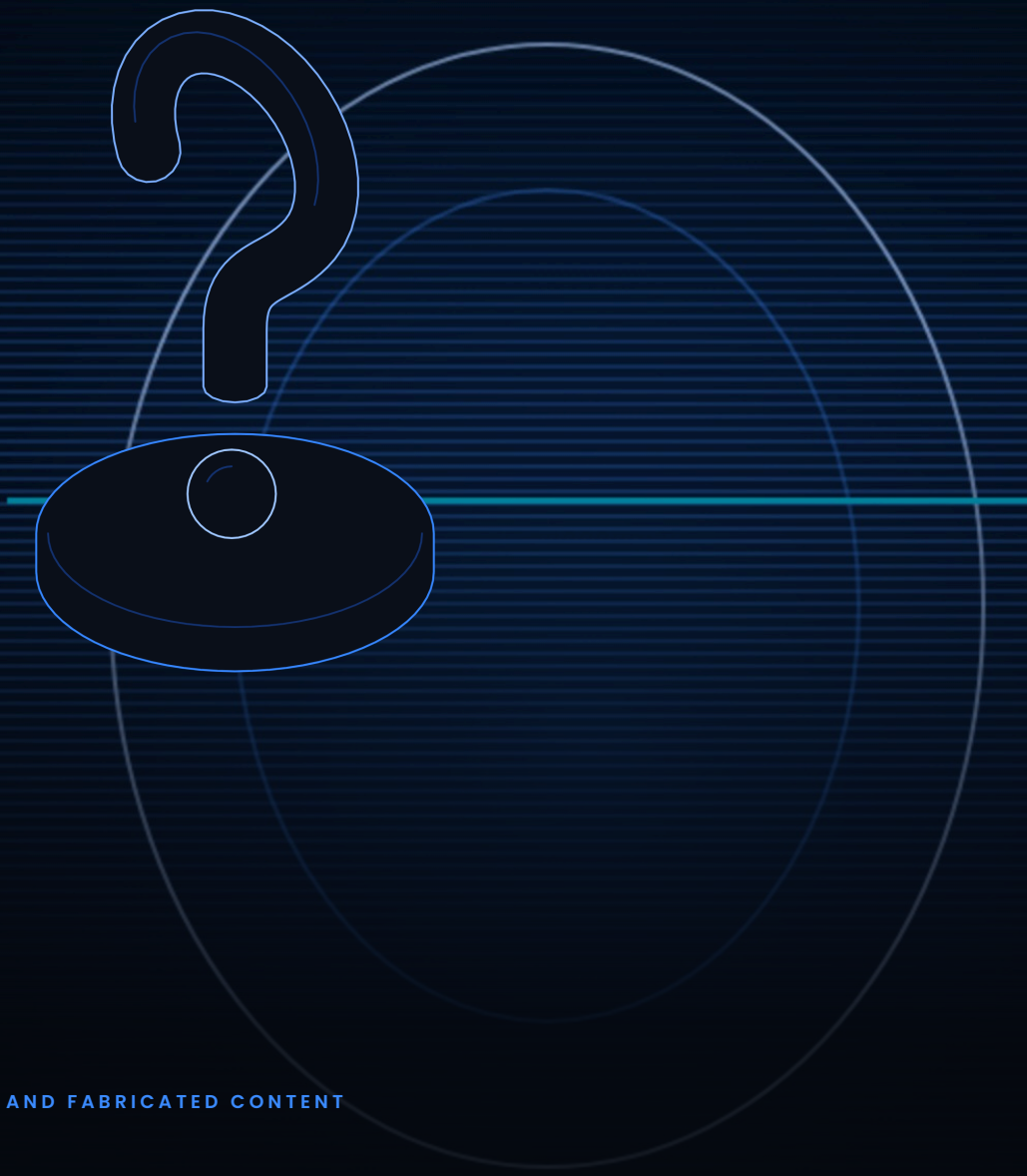
transputec.com

PUT IT INTO PRACTICE

Ready for the AI Act · Playbook No. 15

TRANSPUTEC

HOT TOPICS · PLAYBOOK
NO. 16 · NOVEMBER 2026



HOT TOPICS · AI IMPERSONATION AND FABRICATED CONTENT

Trust, but verify.

A familiar voice on the phone, a familiar face on a video call, a confident citation in a draft. All three can now be fake. A practical playbook for building checks into the moments that matter.

INSIDE

Contents

A practical guide to AI impersonation and AI-fabricated content: what happened, then how to build verification into payments, approvals and professional work this week, this month and this quarter.

Foreword 03

Introduction 04

01 What happened 06

02 Protect payments and approvals 09

03 Check the work AI does 15

Sources 24

FOREWORD

Seeing and hearing is no longer believing.

In early November 2026, federal prosecutors in New York announced charges against three men accused of using AI to mimic the voices, and sometimes the faces, of chief executives and lawyers. Prosecutors allege the scheme took more than $129 million from companies including hospital systems, banks and a UK fintech firm. The charges are allegations and have not been proved.

In the same week, courts in England and India were dealing with something quieter but related: legal documents that cited cases that do not exist. One was filed by a prosecutor, another by a government authority. Neither involved criminals. Both involved people trusting material that looked right and was not.

The two problems share a root. Generative AI makes convincing content cheap, whether that content is a cloned voice or a plausible paragraph of law. The answer in both cases is the same discipline: decide in advance where you will check, and make the check part of the process rather than a matter of instinct. This playbook shows how.



The Transputec team
Transputec

INTRODUCTION

Three habits stop most of the damage.

None of these needs new technology. They need clear rules, practised in advance, that hold even when the person on the screen looks and sounds exactly like your chief executive.

Verify money on a second channel

Any new payment, urgent transfer or change of bank details is confirmed by calling back on a number you already hold, and approved by two people.

Treat voice and video as claims, not proof

A call can be faked. Use code words, call-backs and a pause before acting on any unusual request from a senior person.

Check AI work before it leaves

Every citation, figure, quote and name in AI-assisted work is checked against a source by a named person before it goes to a client, court or regulator.

If a request only makes sense because of who seems to be asking, check who is asking.

Impersonation works by borrowing authority. Verification works by refusing to lend it without proof.

01

PART 01

What happened.

An alleged $129 million impersonation scheme, a run of fake legal citations, and why they belong in the same conversation.

01 The cases in brief

02 How the alleged scheme worked

03 What they have in common

THE NEWS

Fake bosses, fake lawyers, fake law

> **In both stories, nobody broke a system. People trusted content that looked right.**

On 5 November 2026, the US Attorney's Office for the Southern District of New York announced an indictment against three men. Prosecutors allege that between July 2024 and February 2026 they used AI to impersonate the voices and images of executives and lawyers at major firms, and took more than $129 million from companies worldwide.[1] Two were arrested in Spain and one in the UK; extradition requests are pending.[2] All are presumed innocent.

The alleged method was simple. An email, supposedly from the chief executive, asked someone in accounts to help with a confidential transaction. A phone or video call followed in which AI mimicked the executive's voice and sometimes face. The employee was then passed to a supposed lawyer, also fake, who gave the payment instructions.[2] Named victims include hospital systems, banks and a UK fintech firm.[1]

This is not new in shape. In 2024 the engineering firm Arup confirmed that an employee in Hong Kong made 15 transfers totalling HK$200 million, about $25 million, after a video call with what appeared to be senior colleagues. Arup said fake voices and images were used and none of its internal systems were compromised.[3]

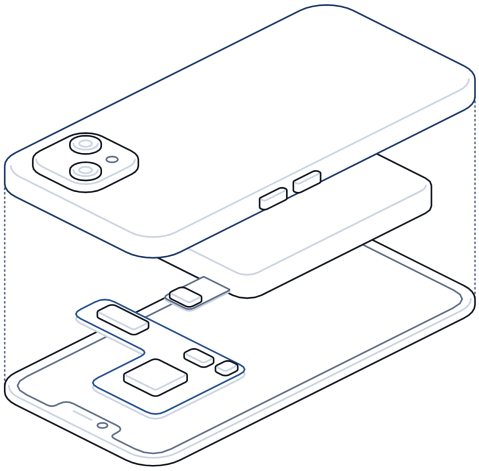
Fabricated content is reaching courts too. In early November a High Court judgment in England recorded that a prosecutor had cited a Court of Appeal case that does not exist; the court found the explanation unsatisfactory but said it did not change the outcome.[4] In 2025 the High Court warned that freely available AI tools are not capable of reliable legal research.[5]

A public database of court decisions involving AI-fabricated material listed 2,266 cases worldwide by 5 November 2026, about 90 of them in the UK.[6] The Solicitors Regulation Authority issued a formal warning notice in August 2026 after 42 reports of potential AI misuse.[7]

The thread joining these stories is trust in what looks and sounds right. The fix is to stop relying on that feeling and build checks into the process instead.

HOW THE ALLEGED SCHEME WORKED

Four steps from an email to a wire transfer, as alleged



01 **The pretext email**

A message appearing to come from the chief executive asks accounts staff to help with a confidential financial transaction.[2]

02 **The cloned call**

A phone or video call follows in which AI mimics the executive's voice and sometimes image, lending the request authority.[2]

03 **The fake adviser**

Staff are passed to a supposed lawyer at a major firm, also impersonated, who supplies payment instructions.[1]

04 **The fast exit**

Money is wired to accounts around the world and, prosecutors allege, converted to cryptocurrency to hide where it went.[2]

02

PART 02

Protect the money.

Controls that still work when the voice, the face and the email all look genuine.

01 The payment change control

02 Verifying voice and video

03 Training that sticks

THE CONTROL

The payment and bank details check

Use this every time a payment is new, urgent, unusual or follows a change of bank details. No exceptions for seniority.

Pause

Any request that is urgent, confidential or outside normal process triggers the check, whoever appears to be asking.

Call back on a known number

Ring the requester or supplier on a number already held in your records, never one given in the request.

Second approver

A second person, who was not on the original call or email thread, approves the payment in the banking system.

Confirm the payee

Use your bank's Confirmation of Payee result and treat a mismatch as a stop, not a warning.

Record it

Log who verified, how and when. The record protects staff who said no and helps if money must be recovered.

> **The NCSC advises verifying important email requests using a second type of communication.[8] The same logic applies to calls and video.**

MATCH THE CHECK TO THE REQUEST

Which verification for which request

Higher risk requests need stronger checks. Agree this table with finance and put it on one page.

REQUEST	MINIMUM CHECK	RED FLAGS
New supplier or payee	Call back on an independently sourced number; two-person approval.	Pressure to skip onboarding; personal or overseas account.
Change of bank details	Call back on number held before the change; wait period for large sums.	Change arrives by email only, or close to a payment date.
Urgent executive request	Call back on the executive's known mobile; code word; second approver.	Secrecy, unusual hours, a third party taking over instructions.
Request on a video call	End the call and ring back on a known number before acting.	Camera issues, short call, refusal to switch channel.
Instructions from a lawyer or adviser	Verify the firm and person through its public switchboard.	New contact, personal email, unfamiliar escrow or holding accounts.

VOICE AND VIDEO

Five rules for verifying a call

Assume a voice or face can be copied. These rules work regardless of how good the fake is.

01 Agree code words for executives

Senior leaders and their finance and executive assistants share a phrase that is never written in email or chat. The FBI recommends a secret word for the same reason.[9]

02 Hang up and call back

For any unusual request, end the call and ring a number you already hold. The FBI gives the same advice for suspected voice cloning.[9]

03 Ask something only they would know

A recent internal meeting, not a fact found online. Public profiles feed the fakes.

04 Never move money on one channel alone

A request made on a call is confirmed in writing through a known system, and the other way round.

05 Make it safe to say no

Leaders state publicly that they will never be offended by a call-back, and that staff who pause will be backed.

REMEMBER

If the request is real, a two-minute check costs nothing. If it is fake, it saves everything.

IN PRACTICE

Three scenarios to rehearse

FINANCE TEAM

The chief executive on video

THE SCENARIO

A video call from the chief executive asks for an urgent, confidential transfer to complete an acquisition.

THE RIGHT MOVE

Pause, end the call, ring the executive's known mobile and ask for the code word.

WHAT GOOD LOOKS LIKE

The payment waits for a second approver, whatever the deadline.

PITFALL

Accepting a callback number or meeting link supplied in the request itself.

ACCOUNTS PAYABLE

The supplier's new bank account

THE SCENARIO

A trusted supplier emails new bank details a day before a large invoice is due.

THE RIGHT MOVE

Call the supplier on the number held before the change and confirm the details verbally.

WHAT GOOD LOOKS LIKE

The change is held until verified, and the check is logged.

PITFALL

Replying to the email to confirm. The attacker may control that thread.

EXECUTIVE ASSISTANTS

The lawyer who needs it today

THE SCENARIO

A caller says they are a partner at a well-known firm acting on a confidential deal.

THE RIGHT MOVE

Ring the firm's public switchboard and ask for the person by name before sharing anything.

WHAT GOOD LOOKS LIKE

No information or payment moves until the firm confirms the instruction.

PITFALL

Being reassured by a convincing name, accent or email signature.

TRAINING

Training that changes behaviour

Annual click-through modules do not prepare people for a convincing call from their boss.

Use realistic scenarios

Rehearse the three scenarios in this playbook with the people who handle money, using your own executives' names.

Practise the pause

Teach one reflex: urgency plus secrecy plus money means stop and verify. Make the pause a habit, not a judgement call.

Include leaders

Executives should know they are the ones being copied, limit what they post, and model the call-back themselves.

Repeat and refresh

Short sessions every quarter, with real examples from the news and from your own near misses.

> **Reward the person who stopped a payment that turned out to be real. That is how the habit survives.**

03

PART 03

Check the work.

Fabricated content does not need a criminal. It only needs a busy person and an unchecked draft.

01 Why fabricated content gets through

02 A checking routine

03 Policy and incidents

FABRICATED CONTENT

Why confident errors slip past good people

> **AI output is a first draft from a fast, fluent colleague who sometimes invents things.**

AI assistants write fluent, well-structured text. That fluency is the problem. A made-up case name in the right format, with a plausible year and court, reads exactly like a real one. A figure with one decimal place looks more precise than a rounded guess, even when it was invented.

Courts have seen this repeatedly. In 2025 the High Court in London dealt with two cases in which lawyers had put fake authorities before the court, one involving 45 fake citations or quotations, and said freely available tools are not capable of reliable legal research.[5] In August 2026 the Solicitors Regulation Authority warned that individuals remain responsible for the work they produce, whether or not AI is used.[7]

The judiciary applies the same rule to itself. Guidance for judges in England and Wales says they are personally responsible for material produced in their name and warns that AI tools can invent cases and quotations.[10]

The risk is not limited to lawyers. Consultants, accountants, surveyors, HR teams and anyone producing reports for clients or regulators face the same failure: a draft that looks finished, a deadline, and no clear rule about who checks what.

Most errors get through for organisational reasons, not technical ones. Nobody is named as the checker. Juniors assume seniors will review; seniors assume juniors checked. Approved tools are not distinguished from public chatbots. And when an error is found, a second AI prompt is used to explain it, which can make it worse.

The fix is a routine that treats every factual element in AI-assisted work as unverified until a named person has traced it to a source.

A CHECKING ROUTINE

Four things to check before anything goes out

Apply this to any AI-assisted document going to a client, court, regulator, board or the public.

Citations and references

Open every case, statute, standard or paper in an authoritative source. If you cannot find it, it does not go out.

Figures and calculations

Trace each number to your own systems or a published source. Recalculate anything that drives a decision.

Quotes and attributions

Check that quoted words appear in the source and that the person or body actually said them.

Names, dates and facts

Confirm people, organisations, dates and events. AI often blends similar names or shifts dates.

> Record who checked and how. A short sign-off line on the file is enough.

POLICY

Five rules for AI in professional advice

A short policy, applied consistently, does more than a long one nobody reads.

01 **Use approved tools only**

Business-grade tools with suitable data protections. No client data in public chatbots.

02 **A named person owns every output**

The author signs off the content as if they wrote every word, because professionally they did.

03 **Verify before you rely**

No citation, figure or quotation leaves the building until it has been traced to a source.

04 **Supervisors check the checking**

Reviewers ask how facts were verified, not just whether the draft reads well.

05 **Be open about use**

Tell clients and courts when AI was used where rules or contracts require it, and keep a record.

WHEN IT GOES WRONG

Incident steps for fakes and fabrications

Speed matters for payments; candour for fabricated content.

01 Payment sent to a fraudster

Call your bank at once to stop or recall the funds, then report to Action Fraud or Police Scotland.

02 Suspected deepfake call or message

Do not act. Keep the call log, messages and any recording; alert security and finance.

03 Fabricated content found after release

Tell the recipient promptly, correct the record and identify every other document from the same source.

04 Court or regulator involved

Inform the court or regulator quickly and honestly. Check whether you have a duty to self-report.

05 Learn and fix

Review what failed: the control, the training or the tool. Update the process and share lessons.

REMEMBER

Do not use an AI tool to explain an AI error. Go back to the source.

THE PLAN

This week, this month, this quarter

A realistic sequence for a mid-sized UK organisation. Adjust owners to suit.

WHEN	PAYMENTS AND APPROVALS	AI-ASSISTED WORK	OWNER
This week	Brief finance on call-back rule; agree executive code words.	Remind staff: no unchecked AI citations or figures go out.	Finance director, heads of practice
This month	Publish verification table; enforce two-person approval in banking.	Publish a short AI use policy and checking routine.	Finance, risk, legal
This quarter	Run a test call; review exceptions and near misses.	Audit a sample of AI-assisted outputs for errors.	Internal audit, security
Ongoing	Quarterly scenario training for money handlers and assistants.	Supervisor checks recorded on each file.	HR, team leaders

QUESTIONS TO ASK

Questions for the board and your suppliers

Ask for evidence that the controls exist and are used.

FOR THE BOARD

- ? Could one person, on one call, move a large sum of our money today?
- ? Do our executives have code words, and have we tested them?
- ? Who checks AI-assisted work before it reaches clients, courts or regulators?

FOR SUPPLIERS AND ADVISERS

- ? How do you verify a change to our bank details before acting on it?
- ? Do you use AI in work you deliver to us, and how is it checked?
- ? What will you tell us if AI-fabricated content is found in your work for us?

CHECKLIST

Are your checks in place?

Tick what exists today. Anything left blank is your next action.

- [ ] **Call-back on a known number for every payment change**
  Never a number supplied in the request.
- [ ] **Two-person approval enforced in the banking platform**
  Not just written in a policy.
- [ ] **Code words agreed for senior leaders**
  Shared with assistants and finance, never written in email.
- [ ] **Scenario training for staff who handle money**
  Repeated at least quarterly.
- [ ] **A short AI use policy covering professional work**
  Approved tools, data rules and sign-off.
- [ ] **A checking routine for citations, figures and quotes**
  With a named checker on each file.
- [ ] **Incident steps for fraud and fabricated content**
  Including bank, Action Fraud and regulator contacts.

GLOSSARY

Words worth knowing

Deepfake

Audio, image or video generated or altered by AI to make someone appear to say or do something they did not.

Voice cloning

Using AI to copy a person's voice from recordings so new speech sounds like them.

Hallucination

A confident AI output that is wrong or made up, such as a case that does not exist.

CEO fraud

A scam in which criminals pose as a senior executive to get staff to make payments or share data.

Mandate fraud

Tricking an organisation into changing a supplier's bank details to an account the criminal controls.

Call-back

Verifying a request by contacting the person on a number already held, not one supplied in the request.

Code word

A pre-agreed phrase used to confirm identity on calls, never shared in writing.

Confirmation of Payee

A UK banking check that compares the account name you enter with the name on the account.

Two-person approval

A control requiring a second, independent person to approve a payment.

Authorised push payment fraud

When a victim is tricked into authorising a payment to a fraudster.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

1 NBC News, 3 foreign nationals allegedly used AI to mimic CEOs in $129M scheme, DOJ says, 6 Nov 2026. nbcnews.com/news/us-news/3-foreign-nationals-allegedly-used-ai-mimic-ceos-129m-scheme-doj-says-rcna607818

2 CBS News (AP), 3 allegedly used AI to steal some $129 million from companies by impersonating executives and lawyers, 6 Nov 2026. cbsnews.com/news/3-ai-steal-129-million-companies-impersonating-executives-lawyers

3 CNN, British engineering giant Arup revealed as $25 million deepfake scam victim, 16 May 2024. edition.cnn.com/2024/05/16/tech/arup-deepfake-scam-loss-hong-kong-intl-hnk

4 The Telegraph (via Yahoo News), Prosecutor cites fake case in court after using AI, 3 Nov 2026. yahoo.com/news/world/articles/prosecutor-cites-fake-case-court-142958367.html

5 Legal Futures, Court issues stark warning to lawyers over AI-generated fake cases (Ayinde and Al-Haroun, [2025] EWHC 1383 (Admin)), 6 Jun 2025. legalfutures.co.uk/latest-news/court-issues-stark-warning-to-lawyers-over-ai-generated-fake-cases

6 D. Charlotin, AI Hallucination Cases database, accessed 8 Nov 2026 (2,266 cases as of 5 Nov 2026). damiencharlotin.com/hallucinations

7 Legal IT Insider, SRA issues AI usage warning notice, 17 Aug 2026; SRA warning notice: sra.org.uk/solicitors/guidance/misuse-ai. legaltechnology.com/sra-issues-ai-usage-warning-notice

8 NCSC, Phishing attacks: defending your organisation. ncsc.gov.uk/guidance/phishing

9 FBI IC3, Criminals use generative artificial intelligence to facilitate financial fraud (I-120324-PSA), 3 Dec 2024. ic3.gov/PSA/2024/PSA241203

10 Courts and Tribunals Judiciary, Artificial Intelligence (AI) guidance for judicial office holders, Oct 2025. judiciary.uk/wp-content/uploads/2025/10/Artificial-Intelligence-AI-Guidance-for-Judicial-Office-Holders-1.pdf

TRANSPUTEC

Build the check into the process.

Transputec helps UK organisations harden payment and approval controls, train staff with realistic impersonation scenarios and put safe, checked AI use into everyday work.

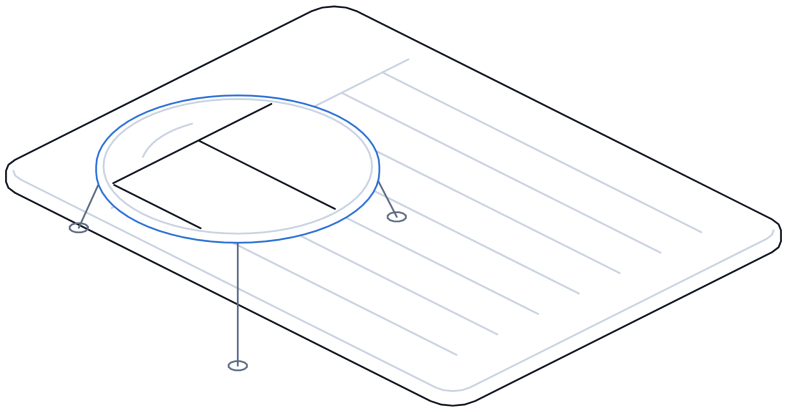
Book a verification review

transputec.com

READ THE COMPANION REPORT

Companion report: Fakes at scale





INTELLIGENCE REPORT · AI IMPERSONATION AND FABRICATED CONTENT

Fakes at scale.

A New York indictment alleging $129 million stolen with cloned voices of executives and lawyers, courts confronting judgments and filings built on cases that do not exist, and why verification now has to be designed in.

INSIDE

Contents

An evidence-based look at AI impersonation fraud and AI-fabricated content in courts: the alleged $129 million scheme charged in New York, the Arup deepfake call, the run of fake legal citations, and what UK organisations should do now.

Executive summary 03

Key findings 04

At a glance 05

Timeline 06

01 The cases 07

02 How the fakes work 11

03 What it means for UK organisations 16

Sources 22

EXECUTIVE SUMMARY

Generative AI has made convincing fakes cheap. The defence is process, not perception.

On 5 November 2026, US prosecutors in Manhattan announced charges against three men accused of using AI to imitate the voices and sometimes the faces of company executives and law firm partners. They allege the scheme ran from July 2024 to February 2026, targeted thousands of companies and took more than $129 million.[1,2] The defendants are presumed innocent, and the allegations have not been tested in court.

The method alleged is an old fraud with new tools: an email from a fake chief executive, a call in which AI supplies the voice, and a fake lawyer who gives the payment instructions.[2] It echoes the 2024 case in which Arup lost about $25 million after a Hong Kong employee joined a video call populated by deepfakes of senior colleagues.[3]

The same week, courts were dealing with a different kind of fake. An English High Court judgment recorded that a prosecutor had cited a case that does not exist, and India's Bombay High Court quashed a customs order that relied on two non-existent Supreme Court judgments.[4,5] A public tracker now lists more than 2,200 court decisions worldwide involving AI-fabricated material.[6]

Both problems exploit the same weakness: people trust material that looks and sounds right. UK organisations should stop asking staff to spot fakes and start requiring checks that hold whether or not the fake is spotted.

THE BOTTOM LINE

Seeing and hearing is no longer believing. Payments, approvals and professional work need verification steps that do not depend on recognising a face, a voice or a plausible citation.

KEY FINDINGS

Seven things the evidence shows

01 **Impersonation fraud now uses AI at industrial scale, prosecutors allege.**

The New York indictment describes thousands of companies targeted and more than $129 million taken over about 19 months.[1]

02 **The target is the payment process, not the IT system.**

In both the alleged scheme and the Arup case, staff authorised the transfers themselves. Arup said none of its internal systems were compromised.[2,3]

03 **Impersonating advisers adds credibility.**

Prosecutors allege staff were passed from a fake chief executive to a fake lawyer, one of whom mainly posed as a UK attorney.[2]

04 **UK businesses are among the victims and the UK is part of the case.**

A UK fintech firm is named among the victims, and one defendant was arrested in the UK.[1,2]

05 **Fabricated content has reached the bench, not only the bar.**

A US appeals court vacated an injunction and reassigned a case after a judge acknowledged AI-generated errors in an order.[7]

06 **UK regulators have moved from guidance to warnings.**

The SRA issued a formal warning notice in August 2026 after 42 reports of potential AI misuse, and a tribunal struck off a lawyer for AI-fabricated citations.[8,9]

07 **The common failure is an unchecked step.**

In every case examined here, a single person acted on, or put forward, material that nobody had independently verified.

AT A GLANCE

The numbers behind the story

Figures for the New York case are allegations from prosecutors and have not been proved.

$129m+

Total prosecutors allege was taken from companies worldwide between July 2024 and February 2026.[1]

HK$200m

About $25 million transferred in 15 payments by an Arup employee in Hong Kong after a deepfake video call.[3]

2,266

Court decisions worldwide involving AI-fabricated content in one public database at 5 November 2026, about 90 in the UK.[6]

45

Fake citations or quotations in one witness statement in a £90 million claim considered by the High Court in 2025.[10]

42

Reports of potential AI misuse received by the SRA between July 2025 and July 2026.[8]

£75.6m

Authorised push payment fraud losses suffered by UK businesses in 2025, according to UK Finance.[11]

TIMELINE

From one deepfake call to a $129 million indictment

Selected events. Dates are as reported by courts, agencies and the press.

Jan to May 2024

Arup deepfake call

A Hong Kong employee makes 15 transfers after a video call with deepfaked colleagues. Arup confirms in May.[3]

Jul 2024

Alleged scheme begins

Prosecutors say the impersonation scheme ran from this month to February 2026.[1]

Dec 2024

FBI warns on generative AI fraud

The FBI says criminals use AI video to impersonate executives in live chats.[12]

6 Jun 2025

High Court warning to lawyers

The Divisional Court says free AI tools cannot do reliable legal research.[10]

17 Aug 2026

SRA warning notice

The SRA warns that solicitors remain responsible for AI-assisted work.[8]

Jun to Sep 2026

Arrests in Spain and the UK

Two defendants are arrested in Spain and one in the UK.[2]

Oct 2026

Order vacated in the US

An appeals court vacates an injunction and reassigns the case after AI errors.[7]

3 Nov 2026

Fake case in an English court

A prosecutor's non-existent citation is recorded in a High Court judgment.[4]

5 Nov 2026

Indictment announced

US prosecutors in Manhattan announce the $129 million charges.[1]

01

PART 01

The cases.

What prosecutors allege in New York, what Arup confirmed in 2024, and what courts are finding in legal filings.

01 The alleged $129 million scheme

02 Impersonation cases compared

03 Fakes in the courtroom

THE NEW YORK INDICTMENT

The alleged $129 million scheme

> **The scheme, as alleged, did not hack anything. It borrowed authority, one convincing call at a time.**

The US Attorney's Office for the Southern District of New York announced the indictment on 5 November 2026. Each of the three defendants faces seven counts, including conspiracy to commit wire fraud, wire fraud, aggravated identity theft and money laundering.[1] They are presumed innocent unless proved guilty.

Prosecutors allege that from July 2024 to February 2026 the group used AI to impersonate the voices and images of corporate executives and of lawyers at major firms.[1] Targets were typically accounting staff with authority to approve large transfers. An email posing as the chief executive asked for help with a confidential transaction, and a phone or video call followed in which AI mimicked the executive's voice and sometimes image.[2]

Staff were then sent to a supposed lawyer, who gave the payment instructions. One defendant, prosecutors say, mainly impersonated UK attorneys using a handwritten script titled "Lawyer Call". The money was allegedly converted to cryptocurrency to hide where it went.[2]

The named victims are ordinary organisations: hospital systems in Missouri and California, a Rhode Island bank, a New York investment bank, a Massachusetts mutual fund company, a Florida pet food company and a UK fintech firm.[1] Two defendants were arrested in Spain and one in the UK between June and September, and extradition requests are pending.[2]

The press release uses the term "SI", for super intelligence, rather than AI. The US Attorney urged businesses to consider how best to protect themselves.[1] Individual loss figures vary between press reports, so we do not repeat them here.

What stands out is not technical sophistication but process design. The alleged scheme layered authority (the chief executive), secrecy (a confidential deal) and outside validation (a lawyer) to override the normal checks on a payment.

IMPERSONATION CASES COMPARED

Same playbook, better tools

Two cases in which staff authorised payments after AI-assisted impersonation. The New York details are allegations.

CASE	WHO WAS FAKED	CHANNEL	REPORTED LOSS	STATUS
Arup, Hong Kong, Jan 2024	Chief financial officer and colleagues	Multi-person video conference[3]	HK$200m, about $25m	Confirmed by Arup; police investigation
Alleged scheme, Jul 2024 to Feb 2026	Chief executives and law firm partners	Email, then phone or video[2]	More than $129m in total	Indicted; presumed innocent
FBI general warning, Dec 2024	Executives, officials, relatives	Live video chat and cloned voice[12]	Not quantified	Public advisory
FBI warning, May 2025	Senior US officials	Texts and AI voice messages[13]	Not quantified	Public advisory

FAKES IN THE COURTROOM

When the citation is the fake

> **A fake citation is checked by opening the source. Most of these were caught only because the other side did.**

The courts' problem began with lawyers and has now reached judges and public authorities. In June 2025 the Divisional Court in London considered two cases in which fake authorities were put before the court, including a witness statement in a £90 million claim containing 45 fake citations or quotations. It said freely available tools such as ChatGPT are not capable of conducting reliable legal research.[10]

In May 2026 a High Court judge found that a junior solicitor at Pinsent Masons had used AI to draft letters to the court that quoted rule text which does not exist. The firm self-reported to the SRA and strengthened its safeguards; the judge said admonishment alone was insufficient but declined to refer the matter for contempt.[14]

In September 2026 the Solicitors Disciplinary Tribunal struck off a registered foreign lawyer whose AI-drafted defence contained false citations, followed by an AI-drafted correction containing more. It was the tribunal's first case on AI hallucinations.[9]

Public bodies are affected too. In early November an English High Court judgment recorded a prosecutor's citation of a Court of Appeal case that does not exist. The CPS said the error arose from legal research using the internet and that its AI policy requires human checks.[4] In India, the Bombay High Court quashed a customs order that relied on two non-existent Supreme Court judgments.[5]

Judges are not immune. In the US, a federal judge acknowledged that an order contained AI-generated errors after a clerk used an AI tool in drafting; the appeals court vacated the injunction and reassigned the case in October 2026.[7] A survey of 360 Korean judges released on 2 November found about 80% of those in civil, family and administrative cases had seen citations to non-existent or fabricated rulings.[15]

The lesson is consistent. Fluent, well-formatted content passes a quick read. It fails only when someone opens the source.

02

PART 02

How the fakes work.

Why cloned voices, synthetic video and invented citations get past capable, careful people.

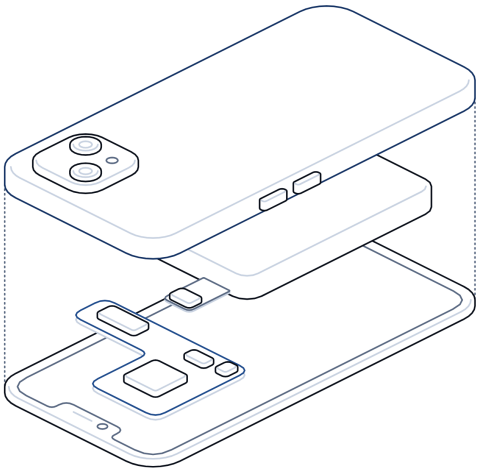
01 Voice and video impersonation

02 Why hallucinations get through

03 Consequences

VOICE AND VIDEO IMPERSONATION

How a cloned call is built and used



01 Collect samples

Voice and video of executives are widely available from interviews, webinars and social media. The FBI advises limiting what is public.[12]

02 Generate the likeness

AI tools produce speech or video in the target's voice and face. The FBI says cloned voices can sound nearly identical to the real person.[13]

03 Set the scene

A pretext email creates urgency and secrecy, then a call adds a familiar voice or face, as alleged in the New York case.[2]

04 Close the loop

A third party, such as a fake lawyer, supplies payment details, so the victim never questions the original instruction.[2]

WHY HALLUCINATIONS GET THROUGH

Plausible is not the same as true

> **Fabricated citations survive because everybody assumes somebody else checked them.**

Large language models generate text by predicting what is likely to come next. A legal citation has a predictable shape: party names, a year in brackets, a court abbreviation, a number. The model can produce that shape without any real case behind it, and the result looks exactly like the genuine article.

Freely available tools do not reliably check their output against authoritative databases. That is why the High Court said in 2025 that they are not capable of conducting reliable legal research, and why the judiciary's own guidance warns judges that AI may invent cases and quotations.[10,16]

Organisational factors do the rest. In the Pinsent Masons case the judge said there was nothing to suggest the junior solicitor had checked any of the references the AI produced.[14] In the tribunal case, AI was used to answer criticism of earlier AI errors, compounding them.[9]

Supervision often checks style rather than substance. A reviewer reads a draft for argument and tone, assumes the references were checked by the author, and signs it off. The author assumed the reviewer would catch anything wrong.

Time pressure, unfamiliar subject matter and a lack of approved tools make things worse. Staff who cannot easily reach a proper legal or financial database will reach for a chatbot instead.

None of this is unique to law. The same failure applies to consultancy reports, tender responses, financial analysis and regulatory returns. Any document whose authority depends on facts is exposed.

TWO FAILURES, ONE ROOT

Impersonation and hallucination side by side

Different actors and intent, but the same control gap.

ASPECT	AI IMPERSONATION	AI-FABRICATED CONTENT
Who creates the fake	Criminals, deliberately.	Usually the organisation's own staff, by accident.
What it exploits	Trust in a familiar voice, face or authority.	Trust in fluent, well-formatted text.
Where it lands	Payment approvals and bank detail changes.	Court filings, client advice, reports and decisions.
What stops it	Call-back on known numbers, code words, two-person approval.	Source checking by a named person before release.
Cost of failure	Money lost, often unrecoverable.	Sanctions, costs, regulatory action and reputational damage.

CONSEQUENCES

Legal and professional consequences so far

Selected outcomes. The New York case is at the charging stage only.

MATTER	CONSEQUENCE	SOURCE
Alleged $129m scheme	Seven counts each; most carry up to 20 years if convicted.	US prosecutors[1]
Fake citations, 2025	Wasted costs, public criticism and regulatory referrals; contempt not pursued.	Divisional Court[10]
Law firm letters, 2026	Published admonishment; firm self-reported to the regulator.	High Court[14]
Foreign lawyer, 2026	Struck off the register; tribunal's first AI hallucination case.	SDT[9]
US injunction, 2026	Injunction vacated and case reassigned to another judge.	Fifth Circuit[7]
Customs order, India	Order quashed by consent and sent back for a fresh hearing.	Bombay High Court[5]

03

PART 03

The UK picture.

Exposure, regulation and the steps that reduce both.

01 What it means for UK organisations

02 Where you are exposed

03 Recommendations

WHAT IT MEANS FOR UK ORGANISATIONS

Verification is now a governance question

> **No regulator has accepted 'the AI wrote it' as a defence. None is likely to.**

UK organisations are already in the story. A UK fintech firm is among the named victims in the New York case, a defendant is alleged to have posed as UK lawyers, and one was arrested here.[1,2] Arup, a UK headquartered firm, was the victim of the best-known deepfake video fraud to date.[3]

The wider fraud picture is still heavy. UK Finance reported £576.4 million lost to authorised push payment fraud in 2025, of which £75.6 million was lost by businesses.[11] Those figures do not isolate AI impersonation, and we do not claim they do. They show the scale of fraud that relies on persuading people to send money.

Official advice already points the right way. The NCSC advises verifying important email requests through a second type of communication and making sure staff know how payments are normally made.[17] The FBI recommends hanging up and calling back on a verified number, and agreeing a secret word.[12]

On fabricated content, UK regulators have been explicit. The SRA's August 2026 warning notice says individuals remain responsible for their work whether or not AI is used, and that failing to heed the notice risks disciplinary action.[8] Judicial guidance says judges are personally responsible for material produced in their name.[16]

Other professions should expect the same logic from their own regulators and clients. Accountants, surveyors, consultants and in-house teams produce work that others rely on, and AI does not shift that responsibility.

The practical conclusion is that verification belongs in governance: owned by named people, written into process, tested and reported to the board, just like any other financial or professional control.

WHERE YOU ARE EXPOSED

Four places fakes reach a UK organisation

You do not need to be a bank or a law firm to be a target.

Payments and bank details

Finance and accounts payable staff who can move money on instruction are the primary target of impersonation.

Executives and assistants

Leaders' public voices and faces feed the fakes; their assistants are often the first point of contact.

Professional and client work

Reports, advice and filings that rely on citations, figures or quotes can carry fabricated content.

Suppliers and advisers

Your law firm, accountant or outsourcer may use AI, and may be impersonated in requests to you.

> If one person on one call can move money, or one unchecked draft can reach a court, that is the gap to close.

RECOMMENDATIONS

Seven things to do now

Based on guidance from the NCSC, the FBI, the SRA and the courts.

01 Make call-back mandatory for payments

Every new payee, urgent transfer and bank detail change is verified on a number already held.[17,12]

02 Require two-person approval

A second, independent person approves payments in the banking system, not just on paper.

03 Agree code words for senior leaders

Shared with finance and assistants, never written down in email.[12]

04 Train with realistic scenarios

Rehearse fake executive, fake supplier and fake lawyer calls with the staff who handle money.

05 Set a checking rule for AI-assisted work

No citation, figure or quote goes out until a named person has traced it to a source.[8]

06 Approve tools and protect data

Use business-grade AI tools with safeguards; keep client data out of public chatbots.[8,16]

07 Prepare incident routes

Know how to contact your bank, Action Fraud and relevant regulators, and how to correct a record.

FOR THE BOARD

Questions to put to your leadership team

Ask for evidence, not reassurance.

PAYMENTS AND IMPERSONATION

- ? Could one person, acting on one call, send a large payment today?
- ? When did we last test our call-back and two-person approval controls?
- ? Do our executives and their assistants use code words?

AI-ASSISTED WORK

- ? Which of our outputs to clients, courts or regulators use AI, and who checks them?
- ? Do our suppliers and advisers use AI in work for us, and how do they verify it?
- ? What would we do if fabricated content were found in something we published?

GLOSSARY

Terms used in this report

Deepfake

Audio, image or video generated or altered by AI to show someone saying or doing something they did not.

Voice cloning

Using AI to reproduce a person's voice from recordings.

Hallucination

A confident AI output that is false or invented, such as a non-existent case.

Indictment

A formal charge in US federal court. It is an allegation, not a finding of guilt.

Authorised push payment fraud

Fraud in which the victim is tricked into authorising a payment to a criminal.

Call-back

Verifying a request by contacting the person on a number already held.

SRA

The Solicitors Regulation Authority, which regulates solicitors in England and Wales.

SDT

The Solicitors Disciplinary Tribunal, which decides serious disciplinary cases against solicitors.

Divisional Court

A High Court sitting of two or more judges, used here to consider lawyers' duties to the court.

Wasted costs

Costs a court orders a lawyer to pay personally because of improper or negligent conduct.

SOURCES

Sources and notes

Sources were accessed in November 2026. Where reports differ, we say so in the text. Early reporting on live incidents can change.

01 NBC News, 3 foreign nationals allegedly used AI to mimic CEOs in $129M scheme, DOJ says, 6 Nov 2026, https://www.nbcnews.com/news/us-news/3-foreign-nationals-allegedly-used-ai-mimic-ceos-129m-scheme-doj-says-rcna607818

02 CBS News (AP), 3 allegedly used AI to steal some $129 million from companies by impersonating executives and lawyers, 6 Nov 2026, https://www.cbsnews.com/news/3-ai-steal-129-million-companies-impersonating-executives-lawyers/

03 CNN, British engineering giant Arup revealed as $25 million deepfake scam victim, 16 May 2024, https://edition.cnn.com/2024/05/16/tech/arup-deepfake-scam-loss-hong-kong-intl-hnk

04 The Telegraph (via Yahoo News), Prosecutor cites fake case in court after using AI, 3 Nov 2026, https://www.yahoo.com/news/world/articles/prosecutor-cites-fake-case-court-142958367.html

05 Bar and Bench, Bombay High Court quashes Customs order flagged for citing non-existent AI-generated judgments, 7 Nov 2026, https://barandbench.com/news/bombay-high-court-quashes-customs-order-flagged-for-citing-non-existent-ai-generated-judgments

06 D. Charlotin, AI Hallucination Cases database, accessed 8 Nov 2026 (2,266 cases at 5 Nov 2026), https://www.damiencharlotin.com/hallucinations/

07 Bloomberg Law, Judge whose ruling had AI-generated errors sees case reassigned, 22 Oct 2026, https://news.bloomberglaw.com/us-law-week/judge-whose-ruling-had-ai-generated-errors-sees-case-reassigned

08 Legal IT Insider, SRA issues AI usage warning notice, 17 Aug 2026, https://legaltechnology.com/sra-issues-ai-usage-warning-notice/ (SRA notice: https://www.sra.org.uk/solicitors/guidance/misuse-ai/)

09 Legal Futures, Lawyer struck off for using fake AI-generated cases before SDT, 4 Sep 2026, https://www.legalfutures.co.uk/latest-news/lawyer-struck-off-for-using-fake-ai-generated-cases-before-sdt

SOURCES

Sources and notes

Sources continued. Details of the New York case are taken from press reports of the US Attorney's announcement; the release itself could not be retrieved directly.

10 Legal Futures, Court issues stark warning to lawyers over AI-generated fake cases ([2025] EWHC 1383 (Admin)), 6 Jun 2025, https://www.legalfutures.co.uk/latest-news/court-issues-stark-warning-to-lawyers-over-ai-generated-fake-cases

11 UK Finance, Annual Fraud Report 2026 press release, 15 Jun 2026, https://www.ukfinance.org.uk/news-and-insight/press-release/fraud-report-2026-press-release

12 FBI IC3, Criminals use generative artificial intelligence to facilitate financial fraud (I-120324-PSA), 3 Dec 2024, https://www.ic3.gov/PSA/2024/PSA241203

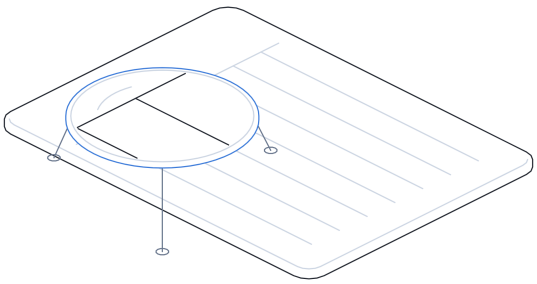
13 FBI IC3, Senior US officials impersonated in malicious messaging campaign (I-051525-PSA), 15 May 2025, https://www.ic3.gov/PSA/2025/PSA250515

14 Legal Futures, Junior solicitor used AI to draft misleading letters to court, 26 May 2026, https://www.legalfutures.co.uk/latest-news/junior-solicitor-used-ai-to-draft-misleading-letters-to-court

15 Seoul Economic Daily, 8 in 10 judges encounter fake case citations in court filings, 2 Nov 2026, https://en.sedaily.com/society/2026/11/02/8-in-10-judges-encounter-fake-case-citations-in-court

16 Courts and Tribunals Judiciary, Artificial Intelligence (AI) guidance for judicial office holders, Oct 2025, https://www.judiciary.uk/wp-content/uploads/2025/10/Artificial-Intelligence-AI-Guidance-for-Judicial-Office-Holders-1.pdf

17 NCSC, Phishing attacks: defending your organisation, https://www.ncsc.gov.uk/guidance/phishing



TRANSPUTEC

Make verification part of the process.

We help UK organisations harden payment and approval controls, train staff against impersonation, and put safe, checked AI use into professional work.

Book a verification review

transputec.com

PUT IT INTO PRACTICE

Companion playbook: Trust, but verify